



RÉPUBLIQUE DU BÉNIN
MINISTÈRE DE L'ENSEIGNEMENT SUPÉRIEUR
ET DE LA RECHERCHE SCIENTIFIQUE

UNIVERSITÉ D'ABOMEY-CALAVI

INSTITUT DE FORMATION ET DE
RECHERCHE EN INFORMATIQUE

BP 526 Cotonou Tel : +229 21 14 19 88
<http://www.ifri-uac.net> Courriel : contact@ifri.uac.bj



MÉMOIRE

pour l'obtention du

Diplôme de Licence en Informatique

Option : Sécurité Informatique

Présenté par :

Modoukpè Safirath **BAKARY**

Gestion centralisée des accès dans une infrastructure distribuée avec Teleport

Sous la supervision :

Ing. Rose GOHOUE

Membres du jury :

Emery ASSOGBA	Docteur	IFRI/UAC	Président
Victor OYETOLA	Ingénieur	IFRI/UAC	Examineur
Rose GOHOUE	Ingénieur	IFRI/UAC	Rapporteur

Année Académique : **2025-2026**

Sommaire

Dédicace	ii
Remerciements	iii
Résumé	iv
Abstract	v
Liste des figures	vi
Liste des tableaux	viii
Liste des sigles et acronymes	ix
Introduction	1
1 Revue de littérature	3
2 Mise en œuvre	11
3 Résultats	26
Conclusion	38
Bibliographie	39
Webographie	40
Annexe	41
Table des matières	44

Dédicace

En mémoire de ma mère, Philomène DOSSOU.

Remerciements

Nous témoignons notre profonde gratitude à Dieu, pour sa protection et ses bénédictions dans notre vie. À travers ce mémoire, nous tenons à remercier :

- Le Professeur Eugène C. EZIN, Directeur de l'Institut de Formation et Recherche en Informatique (IFRI) ;
- Ing. Rose GOHOUE, mon maître de mémoire, pour avoir accepté d'encadrer ce travail ;
- Tous les enseignants d'IFRI, qui ont fourni un grand effort pour nous aider à acquérir le maximum de connaissances nécessaires tout au long de notre formation ;
- Tous les membres de l'administration d'IFRI, qui ont fourni un grand effort pour nous garder sur le droit chemin tout au long de notre formation ;
- Tous ceux et celles qui, de près ou de loin, ont contribué à la réalisation de ce travail.

Résumé

La gestion des accès aux ressources informatiques constitue aujourd’hui un enjeu majeur pour les organisations, dans un contexte marqué par la complexité croissante des infrastructures, la multiplication des menaces liées aux identités et les limites des approches traditionnelles en matière de contrôle des privilèges, de sécurité des accès et de traçabilité des actions. Dans ce contexte, ce travail s’appuie sur la solution open source Teleport afin de mettre en œuvre une architecture centralisée et sécurisée de gestion des accès à différentes ressources informatiques, notamment des serveurs SSH, une base de données MySQL et une application web. Après une présentation des concepts fondamentaux liés à la gestion des accès et une comparaison de solutions existantes, l’architecture proposée et ses mécanismes de sécurité sont décrits. La mise en œuvre dans un environnement de déploiement local a permis d’assurer la centralisation des accès à travers un point de contrôle unique, la segmentation des ressources par environnement, l’application d’un contrôle d’accès basé sur les rôles (RBAC), la gestion des privilèges élevés via des mécanismes d’accès Juste-à-Temps (JIT), l’utilisation de certificats éphémères et de l’authentification multifacteur (MFA) pour l’authentification et le chiffrement des communications, ainsi qu’une traçabilité complète des actions grâce aux mécanismes d’audit et d’enregistrement des sessions. Les résultats obtenus confirment la pertinence de l’architecture conçue en réponse aux enjeux de gestion des accès dans les infrastructures distribuées.

Mots clés : Gestion des accès, Zero Trust, Teleport, RBAC, Accès Juste-à-Temps (JIT).

Abstract

Managing access to IT resources is now a major challenge for organizations, in a context marked by increasingly complex infrastructures, growing identity-related threats, and the limitations of traditional approaches to privilege control, access security, and action traceability. In this context, this work relies on the open source Teleport solution to implement a centralized and secure architecture for managing access to various IT resources, including SSH servers, a MySQL database and a web application. After presenting the fundamental concepts related to access management and comparing existing solutions, the proposed architecture and its security mechanisms are described. Implementation in a local deployment environment has ensured centralized access through a single point of control, segmentation of resources by environment, application of role-based access control (RBAC), management of elevated privileges via Just-In-Time (JIT) access mechanisms, the use of ephemeral certificates and multi-factor authentication (MFA) for authentication and communication encryption, as well as complete traceability of actions through audit and session recording mechanisms. The results obtained confirm the relevance of the architecture designed in response to access management challenges in distributed infrastructures.

Key words: Access management, Zero Trust, Teleport, RBAC, Just-In-Time (JIT) access.

Liste des figures

1.1	IAM et PAM [3]	4
1.2	Les différents types d'accès juste-à-temps [9]	7
1.3	Identité visuelle des outils modernes présentés	8
2.1	Architecture proposée	11
2.2	Installation de Teleport	14
2.3	Création de l'administrateur	15
2.4	Modification du fichier mysqld.cnf	17
2.5	Activation du service de base de données	17
2.6	Fichier YAML du rôle admin	19
2.7	Fichier YAML du rôle role-standard	19
2.8	Fichier YAML du rôle jit-request	20
2.9	Fichier YAML du rôle jit-access	20
2.10	Fichier YAML du rôle marketing	20
2.11	Requête en attente d'approbation	23
3.1	Centralisation des ressources	26
3.2	Accès au serveur SSH-Sandbox	27
3.3	Accès à la base de données DB-Clients	27
3.4	Accès au portail-marketing	27
3.5	Tentative d'accès direct au serveur SSH-Sandbox	28
3.6	Tentative d'accès direct à la base de données	28
3.7	Onglet "Resources" de alice	28
3.8	Onglet "Resources" de jean	28
3.9	Session de bob sur SSH-Sandbox	29
3.10	Session de bob sur DB-Clients	29
3.11	Session de alice sur SSH-Sandbox	30
3.12	Session de cedric sur DB-Clients	30
3.13	Requête d'accès juste-à-temps approuvé	30
3.14	Révocation des privilèges accordés	31
3.15	Certificat éphémère de l'utilisateur alice	31
3.16	Paramètres max_session_ttl et disconnect_expired_cert	32
3.17	Trafic capturé	32
3.18	Authentification multifacteur (MFA)	32
3.19	Journaux d'activités	33
3.20	Logs du scénario de comptes partagés	33
3.21	Enregistrement de sessions ssh	34

3.22	Replay de session ssh	34
A.1	Fichier de configuration teleport.yaml	41
A.2	Fichier de configuration teleport-node1.yaml	42
A.3	Fichier de configuration teleport-node2.yaml	42
A.4	Fichier de configuration de l'application web	43
A.5	Script d'initialisation de la base DB-Clients	43

Liste des tableaux

1.1	Comparaison des solutions modernes de gestion des accès ¹	9
2.1	Justification de la pertinence de l'architecture	13
2.2	Tableau comparatif des serveurs SSH	16
2.3	Politiques d'accès env : dev	19
2.4	Politiques d'accès env : prod	20
2.5	Validation des politiques d'accès (env : dev)	22
2.6	Tests de validation de la traçabilité	25
3.1	Enjeux de gestion des accès vs réponses apportées	35

Liste des sigles et acronymes

Auth : Authentication

CA : Certificate Authority

CE : Community Edition

CLI : Command Line Interface

CN : Common Name

DB : Database

DMZ : Demilitarized Zone

DORA : Digital Operational Resilience Act

FedRAMP : Federal Risk and Authorization Management Program

FIPS : Federal Information Processing Standards

HIPAA : Health Insurance Portability and Accountability Act

HTTPS : HyperText Transfer Protocol Secure

IAM : Identity and Access Management

IdP : Identity Provider

IEC : International Electrotechnical Commission

ISO : International Organization for Standardization

JIT : Just-In-Time

K8s : Kubernetes

LAN : Local Area Network

MFA : Multi-Factor Authentication

mTLS : Mutual Transport Layer Security

NIS2 : Network and Information Security Directive 2

NIST : National Institute of Standards and Technology

PA : Policy Administrator

PAM : Privileged Access Management

PCI-DSS : Payment Card Industry Data Security Standard

PE : Policy Engine

PEP : Policy Enforcement Point

PIN : Personal Identification Number

PKI : Public Key Infrastructure

RBAC : Role-Based Access Control

RDP : Remote Desktop Protocol

RGPD : Règlement Général sur la Protection des Données

SIEM : Security Information and Event Management

SOC 2 : Service Organization Control 2

SOX : Sarbanes-Oxley Act

SQL : Structured Query Language

SSH : Secure Shell

SSL : Secure Sockets Layer

SSO : Single Sign-On

TLS : Transport Layer Security

VLAN : Virtual Local Area Network

VPN : Virtual Private Network

YAML : YAML Ain't Markup Language

ZTA : Zero Trust Architecture

Introduction Générale

Aujourd'hui, les entreprises et organisations font face à des défis croissants en matière de gestion des accès. D'une part, les infrastructures informatiques sont devenues de plus en plus complexes en raison de la diversité des technologies utilisées, de la généralisation du cloud et de la multiplication des environnements distribués. D'autre part, l'identité des utilisateurs constitue désormais une cible privilégiée pour les cyberattaques. Les attaquants exploitent fréquemment des identifiants compromis, recourent à des techniques d'ingénierie sociale ou abusent de privilèges excessifs afin de compromettre des systèmes critiques.

Par ailleurs, les approches traditionnelles de gestion des accès, reposant sur des identifiants statiques, des accès permanents et une administration fragmentée des ressources, montrent aujourd'hui leurs limites face à ces enjeux. Elles entraînent souvent une multiplication des comptes privilégiés, une gestion complexe des autorisations et une traçabilité insuffisante des actions effectuées sur les systèmes. Cette situation accroît la surface d'attaque et complique la mise en conformité avec les exigences réglementaires, qui imposent désormais un contrôle strict et traçable des accès aux ressources sensibles.

Dans ce contexte, les organisations doivent adopter une architecture de gestion des accès permettant une administration centralisée des ressources, tout en s'appuyant sur des mécanismes de contrôle d'accès stricts, sur l'application du principe du moindre privilège et sur des mécanismes de traçabilité et d'audit.

Dès lors, la problématique de ce travail est la suivante :

Comment centraliser et sécuriser efficacement l'accès aux ressources dans une infrastructure informatique complexe et distribuée, tout en assurant la traçabilité des actions?

Pour répondre à cette problématique, ce travail s'appuie sur la solution open source Teleport, qui propose une approche unifiée de gestion des accès fondée sur le modèle Zero Trust, intégrant des mécanismes tels que le contrôle d'accès basé sur les rôles (Role-Based Access Control (RBAC)), l'accès Juste-à-Temps (Just-In-Time (JIT)) et l'audit des sessions.

L'objectif général de ce travail est de concevoir et de mettre en œuvre, à l'aide de la solution open source Teleport, une architecture centralisée et sécurisée de gestion des accès aux ressources d'une infrastructure distribuée, tout en garantissant la traçabilité des actions. De manière spécifique, il s'agira de :

- Concevoir une architecture centralisée de gestion des accès adaptée à une infrastructure distribuée d'entreprise, en définissant les rôles utilisateurs et les politiques d'accès pour des ressources hétérogènes (serveurs Secure Shell (SSH), bases de données, applications web) segmentées par environnement ;

-
- Déployer une instance Teleport auto-hébergée pour centraliser l'accès aux différentes ressources de l'architecture ;
 - Mettre en œuvre le contrôle d'accès basé sur les rôles (RBAC) et l'accès Juste-à-Temps (JIT) pour gouverner les privilèges et réduire la surface d'exposition aux abus de privilèges ;
 - Sécuriser les communications et l'authentification par les certificats éphémères et l'authentification multifacteur (Multi-Factor Authentication (MFA)) en réponse aux risques de vol d'identifiants et d'accès persistants non contrôlés ;
 - Assurer la traçabilité et l'audit des actions des utilisateurs afin de garantir la conformité et de pallier les insuffisances des approches traditionnelles face aux accès partagés non traçables.

Organisation du mémoire:

Ce mémoire est structuré en trois (03) chapitres.

Le premier chapitre présente la revue de littérature, dans laquelle sont exposés les concepts clés nécessaires à la compréhension du sujet, ainsi qu'une analyse comparative de quelques solutions existantes de gestion des accès . Le deuxième chapitre est consacré à la mise en œuvre pratique du projet, de la présentation de l'architecture conçue jusqu'à l'implémentation des différents mécanismes. Le troisième chapitre expose et analyse les résultats obtenus à l'issue des tests réalisés pour valider l'architecture conçue. Enfin, une conclusion générale vient clore le mémoire en résumant les principales étapes de ce travail.

Revue de littérature

Introduction

Ce chapitre présente les concepts fondamentaux liés à la gestion des accès et au modèle Zero Trust. Il présente et compare également différentes solutions existantes de gestion des accès afin de justifier le choix de la solution retenue pour ce mémoire.

1.1 Clarifications conceptuelles

1.1.1 IAM (Identity and Access Management)

La gestion des identités et des accès (Identity and Access Management (IAM)) regroupe l'ensemble des politiques, processus et technologies permettant de garantir que seules les entités autorisées (utilisateurs, systèmes ou applications) accèdent aux ressources appropriées, au bon moment et avec les privilèges adéquats. Au-delà des utilisateurs humains, l'IAM couvre également les identités non humaines, telles que les services, les machines ou les applications.[\[1\]](#).

L'IAM repose sur trois mécanismes fondamentaux : l'identification, qui permet de reconnaître une entité de manière unique ; l'authentification, qui vérifie son identité à l'aide de mécanismes tels que les mots de passe, les certificats ou des facteurs multiples ; et l'autorisation, qui détermine les ressources accessibles et les actions permises selon des privilèges définis.

Dans un contexte marqué par la complexité croissante des systèmes d'information et l'augmentation des menaces, l'IAM constitue un pilier essentiel pour l'application du principe du moindre privilège et la réduction de l'impact des compromissions. Les solutions IAM modernes intègrent notamment la gestion du cycle de vie des identités, le contrôle d'accès granulaire, l'authentification forte, la traçabilité et l'intégration avec des fournisseurs d'identité externes.

Un sous-ensemble critique de l'IAM est la gestion des accès privilégiés (Privileged Access Management (PAM)). Elle vise à contrôler, limiter et auditer l'utilisation des comptes à privilèges élevés (administrateurs, comptes root) afin de réduire la surface d'attaque et de prévenir les abus internes ou externes [\[2\]](#). Une solution PAM permet notamment l'accès juste-à-temps aux ressources sensibles, l'audit et l'enregistrement des sessions privilégiées, la sécurisation des identifiants sensibles, l'authentification multifacteur ainsi qu'un contrôle granulaire des commandes et des actions exécutées.

La figure 1.1 illustre la relation entre IAM et PAM.

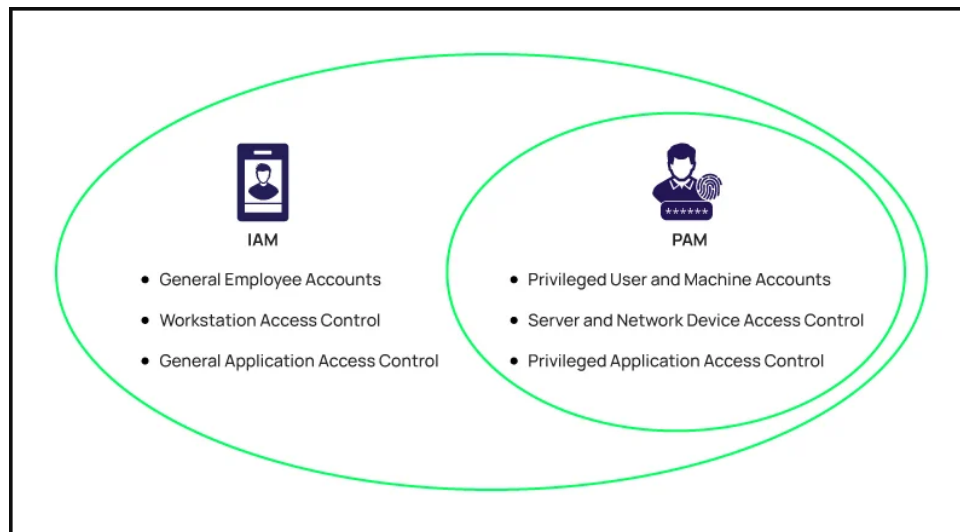


Figure 1.1 – IAM et PAM [3]

1.1.2 Le Modèle Zero Trust

Le modèle **Zero Trust** repose sur le principe fondateur « **Never trust, always verify** », formulé par John Kindervag en 2009 alors qu’il travaillait chez Forrester. [4] Il vise à éliminer toute confiance implicite dans les systèmes d’information en exigeant une vérification systématique de chaque requête d’accès.

Contrairement aux modèles traditionnels basés sur le périmètre, où tout ce qui est « à l’intérieur » du réseau est considéré comme fiable, le Zero Trust considère que toute requête, qu’elle provienne de l’intérieur ou de l’extérieur, doit être systématiquement vérifiée. Cette approche s’est imposée avec l’évolution des infrastructures modernes (cloud, mobilité, télétravail) et la multiplication des attaques ciblant les identités et les privilèges.

Selon les recommandations du **National Institute of Standards and Technology (NIST) SP 800-207 (Zero Trust Architecture)**[5], le modèle Zero Trust repose principalement sur les principes suivants :

- **Principe 1** : Toutes les ressources doivent être protégées. Tout équipement ou service, interne ou externe, est considéré comme une ressource sensible.
- **Principe 2** : Toutes les communications doivent être sécurisées. La localisation réseau n’implique aucune confiance ; les échanges sont chiffrés et authentifiés indépendamment de l’origine.
- **Principe 3** : Accès accordé par session avec des privilèges minimaux. Chaque accès est évalué individuellement et limité aux droits strictement nécessaires.
- **Principe 4** : Politique d’accès dynamique : les décisions d’accès intègrent l’identité, l’état de l’équipement et le contexte de la demande.
- **Principe 5** : Surveillance continue des équipements : la posture de sécurité de chaque équipement est évaluée en permanence ; aucun équipement n’est considéré fiable par défaut.
- **Principe 6** : Authentification et autorisation dynamiques : l’accès fait l’objet d’une réévaluation continue, avec recours au MFA pour les ressources sensibles.

- **Principe 7** : Collecte et analyse continues des données de sécurité : les événements réseau et les accès sont journalisés et analysés pour affiner les politiques de sécurité.

La mise en œuvre du Zero Trust repose sur l'adoption de technologies telles que les solutions IAM et PAM, le contrôle d'accès granulaire (RBAC), l'accès juste-à-temps, l'authentification multifacteur et les mécanismes d'audit.

1.1.3 Authentification et Gestion des Identités

Dans un modèle de sécurité Zero Trust, l'authentification constitue la première étape : elle permet de vérifier de manière fiable l'identité d'un utilisateur, d'une machine ou d'une ressource avant toute tentative d'accès. Pour renforcer cette vérification, plusieurs mécanismes peuvent être mis en place. Cette section présente les principales méthodes utilisées.

1.1.3.1 Authentification Multi-Facteurs (MFA)

L'authentification multifacteur (MFA), également appelée « vérification en deux étapes », est une méthode d'authentification dans laquelle l'utilisateur doit fournir au minimum deux facteurs de vérification pour confirmer son identité. Ces facteurs peuvent être, entre autres, un mot de passe, un code Personal Identification Number (PIN), un jeton ou une caractéristique biométrique. En combinant plusieurs preuves d'identité, le MFA renforce la sécurité de l'identité et réduit les risques de vols d'identifiants et d'accès non autorisés.

1.1.3.2 La PKI (Public Key Infrastructure) et les Certificats Éphémères

Une infrastructure à clés publiques, « Public Key Infrastructure (PKI) », est un ensemble de politiques, de rôles, de matériels, de logiciels et de procédures nécessaires pour créer, gérer, distribuer, utiliser, stocker et révoquer les certificats numériques. Il s'agit d'un système qui permet aux utilisateurs et aux machines d'échanger des données en toute sécurité sur Internet et de vérifier l'identité de l'autre partie.^[6]

Dans ce cadre, les certificats numériques jouent un rôle central en permettant d'authentifier de manière fiable les utilisateurs et les systèmes. Dans les environnements modernes et distribués, l'usage de certificats éphémères, générés dynamiquement et valides pour une durée limitée, est privilégié par rapport aux certificats statiques ou aux mots de passe permanents. Cette approche réduit l'exposition aux compromissions, facilite la rotation automatique des identités et s'inscrit pleinement dans le principe du moindre privilège.

1.1.4 Contrôle d'Accès et Gestion des Privilèges

Une fois l'identité authentifiée, la deuxième étape du modèle Zero Trust est le contrôle d'accès, qui consiste à définir précisément ce qu'un utilisateur ou un système a le droit de faire. L'objectif est d'appliquer le principe du moindre privilège, en limitant les droits d'accès au minimum strictement nécessaire.

1.1.4.1 RBAC (Role-Based Access Control)

Le contrôle d'accès basé sur les rôles (RBAC) est un modèle dans lequel les permissions sont associées à des rôles, et les utilisateurs se voient attribuer ces rôles en fonction de leurs responsabilités. ^[7]

Défini dans le **NIST SP 800-53** sous le contrôle **AC-3**, il constitue le socle de la gouvernance des privilèges en définissant à quoi chaque profil utilisateur peut accéder selon ses responsabilités.

Les principaux avantages du RBAC sont :

- Une gestion centralisée et simplifiée des droits ;
- Une meilleure traçabilité des accès ;
- L'automatisation dans l'attribution des accès et la gestion de la mobilité du personnel.

1.1.4.2 Just-In-Time (JIT) Access

Le Just-In-Time (JIT) Access est une stratégie de sécurité consistant à accorder des privilèges élevés uniquement lorsqu'ils sont nécessaires, pour une durée limitée, puis à les révoquer automatiquement une fois la tâche accomplie, afin de limiter l'exposition aux privilèges permanents et d'appliquer le principe du moindre privilège. [8]

Le JIT complète le RBAC en y ajoutant une dimension temporelle : là où le RBAC définit les droits selon les rôles, le JIT conditionne l'attribution de certains rôles sensibles à une demande explicite et une approbation, limitant ainsi l'existence de privilèges permanents. Cette approche est conforme au principe 4 du **NIST SP 800-207**, qui recommande d'accorder les droits d'accès par session avec les privilèges les plus restrictifs possibles. Nous distinguons trois types d'accès juste-à-temps, comme le montre la figure 1.2 :

- **Accès éphémère** : un compte temporaire est créé spécifiquement pour une tâche donnée, puis automatiquement supprimé une fois celle-ci terminée, supprimant ainsi tout privilège persistant ;
- **Élévation temporaire de privilèges** : l'utilisateur conserve son compte habituel, mais peut demander des privilèges plus élevés si nécessaire, et ce, pour une durée limitée ;
- **Accès basé sur la justification** : les utilisateurs doivent justifier clairement la nécessité d'un accès privilégié. Cette justification est ensuite examinée au regard des politiques prédéfinies afin de déterminer si l'accès doit être accordé.

La mise en œuvre du JIT repose principalement sur les éléments suivants :

- l'attribution dynamique et temporaire des privilèges, avec révocation automatique ;
- l'intégration de mécanismes d'approbation et d'authentification adaptés ;
- la journalisation systématique des demandes et des accès accordés.

L'accès Juste-à-Temps permet ainsi de réduire la surface d'attaque, de limiter les risques d'accès non autorisés et d'améliorer globalement la posture de sécurité des systèmes d'information, tout en facilitant la conformité aux exigences de sécurité et d'audit.

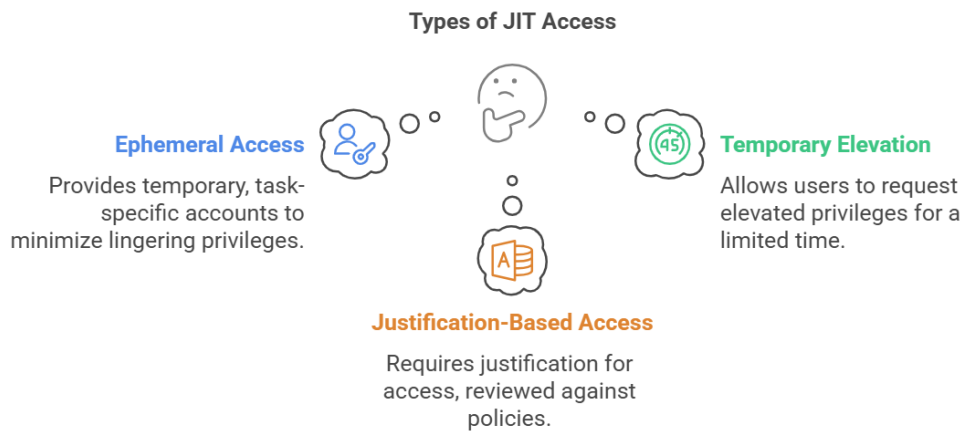


Figure 1.2 – Les différents types d'accès juste-à-temps [9]

1.2 Audit de sécurité et traçabilité des actions

Au-delà de l'authentification et des contrôles d'accès, la surveillance et l'enregistrement des interactions avec les systèmes informatiques constituent un pilier essentiel de la sécurité Zero Trust. L'audit et la traçabilité permettent de surveiller l'accès, de détecter les comportements anormaux et de démontrer la conformité aux exigences de sécurité.

Plusieurs normes et réglementations imposent des exigences en matière de journalisation et de surveillance des accès : International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 27001, Règlement Général sur la Protection des Données (RGPD), Payment Card Industry Data Security Standard (PCI-DSS) et Service Organization Control 2 (SOC 2).

Les systèmes modernes de gestion des accès intègrent plusieurs fonctionnalités essentielles pour assurer un audit et une traçabilité efficaces. Ces fonctionnalités incluent l'enregistrement et la relecture des sessions (SSH, Remote Desktop Protocol (RDP), etc.) ainsi que la journalisation (Logging). Ces mécanismes permettent de :

- Dissuader les comportements malveillants et renforcer la responsabilité des utilisateurs ;
- Fournir des preuves de conformité lors des audits et des contrôles de sécurité ;
- Détecter rapidement les activités suspectes grâce à l'analyse des journaux et des sessions enregistrées.

1.3 Outils existants de gestion des accès

La gestion des accès a évolué au fil du temps pour répondre aux menaces croissantes de sécurité informatique et à la complexité des environnements informatiques. Cette section présente quelques solutions existantes de gestion des accès, allant des approches traditionnelles aux outils de nouvelle génération.

1.3.1 Présentation des solutions traditionnelles de gestion des accès

- **Virtual Private Network (VPN)** : technologie permettant d'établir un tunnel chiffré entre un utilisateur distant et le réseau interne d'une organisation. Bien qu'il assure un accès sécurisé au niveau du réseau, il ne permet ni un contrôle granulaire des accès ni une traçabilité des actions des utilisateurs une fois connectés.
- **Bastion Hosts/jump hosts traditionnels** : Un serveur de saut est un serveur intermédiaire servant de point d'entrée unique vers le réseau interne. Il renforce la sécurité en limitant les connexions directes aux ressources critiques. Toutefois, les bastions traditionnels présentent plusieurs limites : gestion complexe, identifiants statiques, droits souvent trop étendus et faible visibilité sur les activités des utilisateurs.

1.3.2 Présentation des solutions modernes de gestion des accès

- **HashiCorp Boundary** : Boundary est un outil développé par HashiCorp, éditeur de Terraform. Il s'agit d'un proxy sensible à l'identité, qui simplifie l'accès sécurisé aux ressources critiques sur site ou dans le cloud. Intégré à Vault, il génère des identifiants temporaires et peut s'appuyer sur des fournisseurs d'identité externes pour appliquer un contrôle d'accès granulaire.
- **Jumpserver** : JumpServer est un bastion moderne open source de gestion des accès privilégiés (PAM) offrant un accès à la demande et traçable via un navigateur web pour le SSH, le RDP, les clusters Kubernetes ou les bases de données. Il améliore la traçabilité et masque les identifiants réels des ressources.
- **Teleport** : Il s'agit d'une plateforme open-source de gestion des accès unifiés qui implémente les principes du modèle Zero Trust. Elle fournit un accès sécurisé et traçable aux serveurs, bases de données, clusters Kubernetes et applications web, via des certificats éphémères et une PKI interne. Teleport intègre nativement le MFA, le RBAC et l'accès Juste-à-Temps (JIT).
- **StrongDM** : solution Zero Trust centralisant l'authentification, l'autorisation et la supervision des accès aux serveurs, bases de données et environnements cloud. Elle offre un accès sécurisé et contrôlable pendant la durée précise requise au sein d'une même plateforme.

La figure 1.3 illustre l'identité visuelle des différents outils présentés.

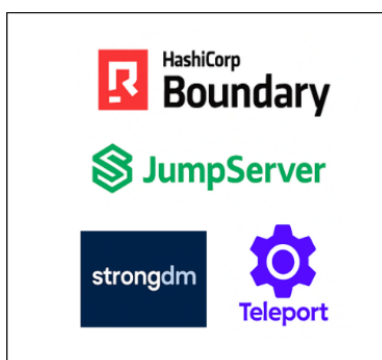


Figure 1.3 – Identité visuelle des outils modernes présentés

1.3.3 Tableau récapitulatif des outils présentés

Le tableau 1.1 compare les outils de nouvelle génération présentés précédemment, en se basant sur des critères spécifiques liés à la gestion moderne des accès.

Critères	Teleport	JumpServer	Boundary	StrongDM
Licence	open source	open source	open source	commercial
Auto-hébergement	Oui	Oui	Oui	local + cloud
Ressources supportées	SSH, DB, RDP, K8s, apps	SSH, DB, RDP, apps	SSH, DB, apps	SSH, DB, RDP, K8s, apps
Authentification forte (MFA)	Oui	Oui	Oui (via IdP)	Oui
Enregistrement/Relecture	Oui	Oui	Non	Oui
Logging	Oui	Oui	Limité	Oui
RBAC	Avancé	RBAC Payant	Limité	Avancé
Just-In-Time	Oui	Oui (Payant)	Oui (via Vault)	Oui

Tableau 1.1 – Comparaison des solutions modernes de gestion des accès ¹

La comparaison des outils présentés dans ce tableau met en évidence des approches différentes de la gestion des accès. Les solutions commerciales proposent généralement des fonctionnalités avancées et intégrées, tandis que d'autres solutions open source privilégient la flexibilité, parfois au prix d'intégrations externes. Certaines fonctionnalités peuvent également être limitées aux éditions payantes. Elle souligne aussi des différences notables en matière de déploiement, allant d'installations locales à des déploiements hybrides. Ces éléments montrent que chaque outil répond à des besoins et des contextes d'usage distincts.

1.3.4 Justification du choix de Teleport

À l'issue d'une analyse comparative de plusieurs outils modernes de gestion des accès, en se basant sur des critères spécifiques, le choix s'est porté sur la solution open source Teleport. Ce choix repose sur cinq points directement alignés avec les objectifs de ce travail :

- **Alignement Zero Trust** : Contrairement aux approches traditionnelles (VPN, bastions SSH) qui reposent sur des secrets statiques, Teleport utilise des certificats éphémères signés par une infrastructure à clés publiques interne (PKI) pour l'authentification des utilisateurs et des services. L'intégration de l'authentification multi-facteur (MFA) renforce la vérification des identités et réduit les risques liés au vol de mots de passe ou de clés d'accès.

¹ Les informations de ce tableau sont issues des documentations officielles : [Teleport](#), [Jumpserver](#), [StrongDM](#), [Boundary](#).

- **Centralisation des accès aux ressources** : Teleport permet de gérer au sein d'une plateforme unique l'accès à des ressources hétérogènes telles que les serveurs SSH, les bases de données et les applications web. Cette approche favorise une administration centralisée des accès et répond aux problématiques liées à la dispersion des mécanismes d'accès dans les environnements distribués.
- **Gouvernance dynamique des accès par le RBAC et le JIT** : Le modèle de contrôle d'accès basé sur les rôles (RBAC) permet une gestion granulaire des autorisations attribuées aux utilisateurs. Associé au mécanisme d'accès Juste-à-Temps (JIT), il permet l'attribution temporaire de privilèges soumis à approbation, limitant ainsi l'existence de droits permanents et réduisant les risques liés aux abus de privilèges.
- **Audit et traçabilité des actions** : La solution intègre des mécanismes d'enregistrement et de relecture des sessions, ainsi qu'un audit détaillé des activités des utilisateurs. Ces fonctionnalités assurent une traçabilité des actions associée à chaque identité et facilitent les processus de supervision et de conformité.
- **Auto-hébergement** : Sa nature open source et son déploiement en mode auto-hébergé permettent un contrôle direct de l'infrastructure de sécurité et une intégration progressive dans différents environnements, tout en limitant la dépendance à des services externes.

En définitive, Teleport ne constitue pas uniquement un outil de connexion aux ressources, mais une plateforme de gestion et de gouvernance des accès permettant de mettre en œuvre l'architecture centralisée et sécurisée conçue pour ce projet. Ses fonctionnalités répondent directement aux objectifs de centralisation, de sécurisation des accès et de traçabilité définis dans ce travail.

Conclusion

Dans ce premier chapitre, nous avons présenté les notions fondamentales pour comprendre le contexte de ce mémoire, notamment à travers des clarifications conceptuelles sur l'IAM, le modèle Zero Trust et ses principes fondamentaux. Nous avons également mis en évidence l'importance de l'audit et de la traçabilité des accès. Enfin, une analyse comparative de différentes solutions de gestion des accès a été menée afin de justifier le choix de Teleport pour notre mémoire. Le chapitre suivant sera consacré à la mise en œuvre du projet.

Mise en œuvre

Introduction

Ce chapitre détaille la démarche suivie pour la mise en œuvre du projet, depuis la présentation de l'architecture conçue jusqu'à son déploiement effectif.

2.1 Présentation de l'architecture conçue

La figure 2.1 présente l'architecture centralisée et sécurisée conçue pour la mise en œuvre.

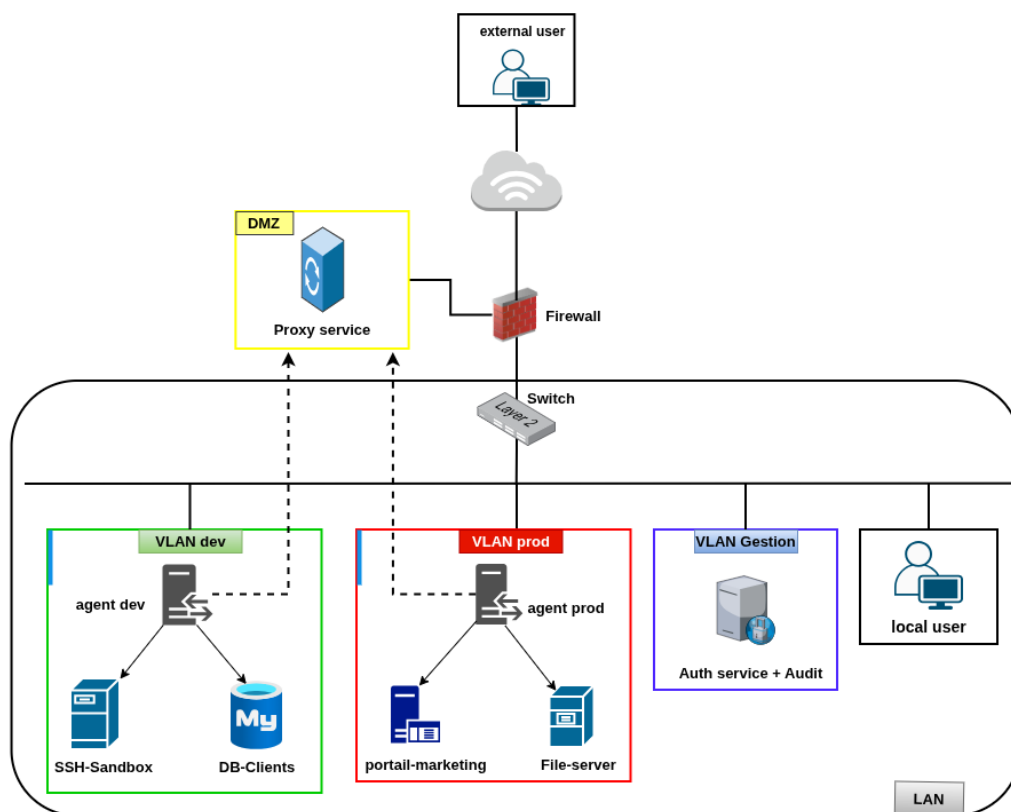


Figure 2.1 – Architecture proposée

2.2 Description technique de l'architecture

L'architecture présentée est structurée autour d'une séparation entre le plan de contrôle et le plan de ressources.

Plan de Contrôle : C'est le cerveau et l'unique autorité de confiance de l'infrastructure.

Il est basé sur les éléments suivants :

- **Service d'authentification (Auth Service) :** Composant central du plan de contrôle, situé dans le Virtual Local Area Network (VLAN) de gestion isolé. Il gère la PKI interne, émet des certificats éphémères, valide les politiques RBAC et JIT, et centralise les événements de sécurité via l'Audit Log.
- **Service proxy (Proxy Service) :** Point d'entrée unique de l'architecture, situé en Demilitarized Zone (DMZ) et exposé sur le port 443. Il sert d'intermédiaire pour tous les accès aux ressources, reçoit les connexions des utilisateurs internes et externes, et maintient les tunnels inverses établis par les agents.

Plan de Ressources : Il regroupe les éléments suivants :

- Les ressources qui sont segmentées en deux VLANs distincts selon leur criticité. Le VLAN **dev** regroupe le serveur **SSH-Sandbox** et la base de données MySQL **DB-Clients**. Le VLAN **prod** regroupe le serveur de fichiers **File-server** et l'application web **portail-marketing**. Cette segmentation permet d'appliquer des politiques d'accès différenciées selon le niveau de sensibilité des ressources.
- Chaque VLAN dispose d'un agent Teleport qui permet d'inscrire les ressources auprès du service d'authentification en passant par le service proxy.

Politiques d'accès et rôles utilisateurs : L'accès aux ressources est régi par des politiques de contrôle basées sur les rôles (RBAC). Les permissions sont attribuées aux utilisateurs en fonction de leurs responsabilités et des labels associés aux ressources. Le plan de contrôle permet également l'attribution dynamique de privilèges grâce au mécanisme Just-In-Time (JIT), où les droits d'accès élevés sont accordés de manière temporaire pour une durée limitée et uniquement lorsque cela est nécessaire. Cette gestion réduit l'exposition permanente aux privilèges élevés et renforce la sécurité de l'infrastructure.

Rôle du firewall : Le firewall contrôle les flux entre internet, la DMZ et le Local Area Network (LAN) interne. Il n'autorise que le flux HyperText Transfer Protocol Secure (HTTPS) entrant sur le port 443 vers le Proxy Service. Tous les autres flux entrants sont bloqués ; les ressources ne sont jamais exposées directement.

Flux de communication :

- **Reverse tunnel :** Les agents Teleport déployés dans chaque VLAN établissent une connexion sortante vers le Proxy Service via un tunnel inverse chiffré. Ce mécanisme évite toute exposition directe des ressources vers l'extérieur, car aucun port entrant n'est ouvert sur celles-ci.

- **Utilisateur externe vers le Proxy** : Les utilisateurs externes accèdent à la plateforme depuis internet via une connexion HTTPS sur le port 443 vers le Proxy Service situé en DMZ. Le firewall n'autorise que ce flux entrant, garantissant que le proxy constitue le seul point d'entrée vers l'infrastructure.
- **Utilisateur interne vers le Proxy** : Les utilisateurs internes accèdent aux ressources via le même Proxy. Aucun accès direct aux ressources n'est autorisé depuis le réseau interne.
- **Proxy et Auth service** : Le Proxy Service communique avec l'Auth Service via Mutual Transport Layer Security (mTLS) pour la validation des identités, l'émission des certificats éphémères et la transmission des événements de session vers l'Audit Log. Cette communication chiffrée garantit l'intégrité des échanges entre les composants du plan de contrôle.

Justification des choix : Les besoins de sécurité auxquels répond l'architecture proposée ont été identifiés en s'appuyant sur deux référentiels reconnus : le **NIST SP 800-207 (Zero Trust Architecture)**[5] qui définit les principes fondamentaux d'une architecture Zero Trust, et le **NIST SP 800-53 (Security and Privacy Controls for Information Systems and Organizations)**[10] qui fournit un catalogue de contrôles de sécurité applicables aux systèmes d'information. Le tableau 2.1 présente les besoins identifiés et les recommandations correspondantes issues de ces deux référentiels.

Besoins de sécurité	NIST SP 800-207	NIST SP 800-53
Centralisation des accès	Architecture ZTA — Plan de contrôle centralisé (PEP/PA/PE)	AC-17 : Accès distant
Gouvernance des privilèges (RBAC/JIT)	Principes 3 et 4 — Accès par session et politique dynamique	AC-3 : Application des accès AC-6 : Moindre privilège
Traçabilité des actions	Principe 7 — Collecte et analyse des données de sécurité	AU-2 : Événements auditable AU-12 : Génération des enregistrements
Sécurité des connexions (MFA/certificats éphémères/TLS)	Principes 2 et 6 — Sécurisation des communications et authentification dynamique	IA-2 : Identification et authentification SC-8 : Confidentialité des transmissions
Protection des ressources sensibles (segmentation)	Principes 1 et 2 — Toutes les ressources sont considérées exposées	SC-7 : Protection des frontières AC-4 : Contrôle des flux d'information

Tableau 2.1 – Justification de la pertinence de l'architecture

AC : Access Control, SC : System and Communications Protection, AU : Audit and Accountability, IA : Identification and Authentication, SP : Special Publication

Cette architecture a été mise en œuvre dans un environnement de déploiement local sur des machines virtuelles, simulant la segmentation et certains des flux décrits ci-dessus. Le flux d'accès depuis un utilisateur externe n'a pas été simulé, l'environnement étant entièrement local. Les adaptations spécifiques à cet environnement (ports utilisés, certificats auto-signés, absence de haute disponibilité) sont détaillées dans la section mise en œuvre.

2.3 Mise en œuvre

2.3.1 Déploiement du plan de contrôle

Le plan de contrôle constitue le composant central de l'architecture conçue. Il assure l'authentification des utilisateurs, le contrôle des accès aux ressources, ainsi que la supervision des actions réalisées sur l'infrastructure. Dans ce travail, ce plan de contrôle est implémenté à l'aide de la solution open source Teleport, qui fournit les services d'authentification, de proxy, de gouvernance des accès et d'audit.

Étape 1 : Installation d'une instance auto-hébergée de Teleport

Teleport repose sur trois composants principaux : le service **teleport**, l'outil d'administration **tctl** et le client Teleport **tsh**. L'installation commence par le téléchargement du binaire compatible avec l'architecture amd64 depuis le site officiel de Teleport <https://goteleport.com/download/>. L'installation est réalisée à l'aide du script fourni, comme illustré à la figure 2.2.

```
root@cluster-VirtualBox:/home/bakary/teleport# sudo ./install
Starting Teleport installation...
Teleport binaries have been copied to /usr/local/bin

Thanks for installing Teleport.

Is it OK if we collect some info about your install?
Please run this command to send in a survey.
Optional: Replace email to join our newsletter and get a swag package.
$ curl -X POST https://usage.teleport.dev -F OS=linux -F use-case="access my ..." -F email="alice@example.com"

Otherwise, ignore!
root@cluster-VirtualBox:/home/bakary/teleport#
```

Figure 2.2 – Installation de Teleport

Étape 2 : Configuration et activation des services

Après l'installation, la configuration du plan de contrôle est effectuée à travers le fichier **teleport.yaml**, qui définit ses paramètres de fonctionnement. Ce fichier est généré à l'aide de la commande :

Génération du fichier de configuration initiale

```
$ sudo teleport configure -o file
```

Elle crée un modèle de configuration que l'on adapte en fonction des besoins du déploiement. Le fichier de configuration du cluster Teleport est présenté en annexe à la figure A.1. Les principaux champs configurés dans ce fichier sont le répertoire de stockage des données et l'activation des services d'authentification et de proxy.

Une fois le fichier configuré, Teleport est démarré avec la commande suivante :

Commande de démarrage

```
$ sudo teleport start --config="/etc/teleport.yaml" --insecure
```

L'option **--insecure** permet d'éviter les erreurs liées à l'utilisation de certificats auto-signés.

Étape 3 : Administration du plan de contrôle

Une fois Teleport opérationnel, un premier utilisateur disposant des droits d'administration est créé afin de permettre l'administration du plan de contrôle depuis l'interface Web. Pour ce faire, la commande suivante est exécutée :

Création de l'administrateur

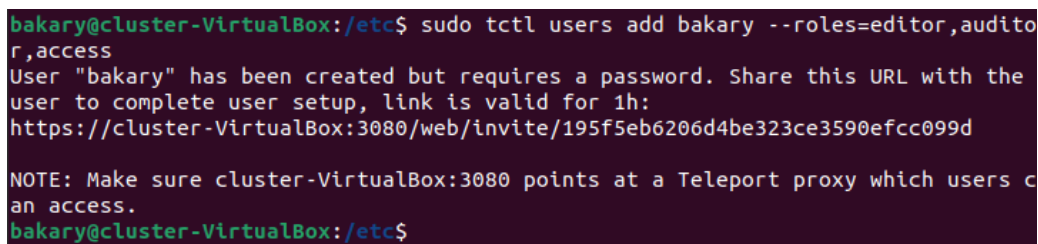
```
$ sudo tctl users add bakary --roles=editor,auditor,access
```

Les rôles spécifiés ci-dessus sont des "**preset roles**". Il s'agit de rôles prédéfinis dans Teleport servant de base pour la gestion des accès. Ils déterminent le niveau de privilèges accordé à chaque utilisateur.

Le rôle **access** autorise l'accès à l'ensemble des ressources du cluster, **editor** permet la modification de la configuration (rôles, connecteurs et ressources), tandis que le rôle **auditor** offre un accès en lecture seule aux journaux d'audit et aux enregistrements de sessions.

Cette commande génère un lien d'inscription temporaire permettant la définition du mot de passe et l'activation de l'authentification multifacteur (MFA) pour ce compte.

La figure 2.3 présente la sortie obtenue à l'issue de cette opération.



```
bakary@cluster-VirtualBox:/etc$ sudo tctl users add bakary --roles=editor,auditor,access
User "bakary" has been created but requires a password. Share this URL with the
user to complete user setup, link is valid for 1h:
https://cluster-VirtualBox:3080/web/invite/195f5eb6206d4be323ce3590efcc099d

NOTE: Make sure cluster-VirtualBox:3080 points at a Teleport proxy which users can access.
bakary@cluster-VirtualBox:/etc$
```

Figure 2.3 – Création de l'administrateur

Ainsi, ces étapes permettent de mettre en place l'infrastructure centrale sur laquelle reposent l'intégration des ressources et l'application des politiques d'accès décrites dans la suite de la mise en œuvre.

2.3.2 Intégration du plan de ressources

Le plan de ressources regroupe l'ensemble des ressources accessibles via le plan de contrôle. Ces ressources hétérogènes représentent différents types d'accès présents dans un environnement réel : serveurs SSH, bases de données et applications web. Leur intégration permet d'illustrer la gestion centralisée des accès à des ressources de natures différentes.

2.3.2.1 Intégration des serveurs SSH

Étape 1 : Installation de l'agent Teleport

L'agent Teleport est installé à l'aide de la commande suivante :

Installation de l'agent Teleport

```
$ sudo curl https://goteleport.com/static/install.sh | bash -s 17.4.7
```

Étape 2 : Configuration des nœuds

Deux fichiers de configuration distincts sont ensuite créés : **teleport-node1.yaml** et **teleport-node2.yaml**. La structure complète de chacun de ces fichiers de configuration est présentée en annexe aux figures [A.2](#) et [A.3](#).

Les principales différences entre ces deux fichiers sont résumées dans le tableau [2.2](#) :

Éléments	Serveur 1	Serveur 2
nodename	SSH-Sandbox	File-server
data_dir	/var/lib/teleport-node1	/var/lib/teleport-node2
listen_addr	0.0.0.0:3022	0.0.0.0:4022
label	env=dev	env=prod, role : file_server

Tableau 2.2 – Tableau comparatif des serveurs SSH

Étape 3 : Génération des jetons d' enrôlement

Depuis le cluster, deux jetons d'inscription temporaires sont générés à l'aide de la commande suivante :

Génération du jeton d'inscription

```
$ sudo tctl nodes add --roles=node --ttl=30m
```

Étape 4 : Démarrage des agents

Une fois les jetons générés, les agents Teleport sont démarrés à l'aide des commandes suivantes :

Démarrage des agents

```
$ sudo teleport start --config="/etc/teleport-node1.yaml"
--auth-server=192.168.1.70 --token=<token_node1>

$ sudo teleport start --config="/etc/teleport-node2.yaml"
--auth-server=192.168.1.70 --token=<token_node2>
```

où **<token_node1>** et **<token_node2>** correspondent aux jetons d' enrôlement générés précédemment.

2.3.2.2 Intégration de la base de données MySQL

Une base de données MySQL a été intégrée au plan de ressources. Cette intégration suit les étapes suivantes :

Étape 1 : Création de la base

Une base de données **DB-Clients** a été créée, contenant la table **accounts**, avec deux utilisateurs aux droits distincts. Aucun mot de passe n'a été défini pour ces utilisateurs, car Teleport utilisera des certificats Transport Layer Security (TLS) pour les authentifier. Le script d'initialisation de la base est présenté en annexe à la figure [A.5](#)

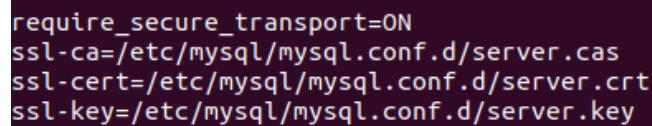
Étape 2 : Génération des certificats TLS

Pour que MySQL fasse confiance à Teleport, une paire de certificats ainsi qu'une clé privée sont générées par l'autorité de certification du cluster :

Génération des certificats TLS

```
$ sudo tctl auth sign --format=db --host=192.168.1.71 --out=server  
--ttl=2160h
```

Cette commande produit trois fichiers : **server.cas** (Certificate Authority (CA)), **server.crt** (certificat serveur) et **server.key** (clé privée). Ils sont copiés sur la machine hébergeant MySQL et le serveur est configuré pour exiger les connexions TLS via le fichier **mysqld.cnf**, comme illustré à la figure [2.4](#)

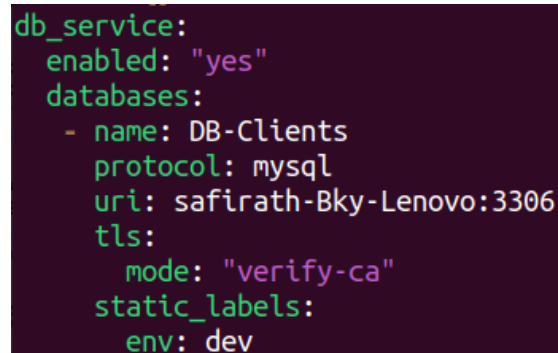


```
require_secure_transport=ON  
ssl-ca=/etc/mysql/mysql.conf.d/server.cas  
ssl-cert=/etc/mysql/mysql.conf.d/server.crt  
ssl-key=/etc/mysql/mysql.conf.d/server.key
```

Figure 2.4 – Modification du fichier mysqld.cnf

Étape 3 : Activation du service de base de données dans Teleport

Le service **db_service** est activé dans le fichier de configuration YAML Ain't Markup Language (YAML) de l'agent Teleport. La figure [2.5](#) illustre la configuration ajoutée :



```
db_service:  
  enabled: "yes"  
  databases:  
    - name: DB-Clients  
      protocol: mysql  
      uri: safirath-Bky-Lenovo:3306  
      tls:  
        mode: "verify-ca"  
      static_labels:  
        env: dev
```

Figure 2.5 – Activation du service de base de données

2.3.2.3 Intégration de l'application web

Afin de représenter l'accès aux applications métiers, une application web basée sur un serveur Nginx a été intégrée au plan de ressources. Cette intégration permet la gestion de l'accès aux services HTTP via le proxy applicatif de Teleport.

Activation du service applicatif

L'intégration de l'application repose sur l'activation du service applicatif (**app_service**) dans le fichier de configuration de l'agent Teleport. Ce service permet d'enregistrer l'application auprès du plan de contrôle et de la rendre accessible via le proxy. Le fichier de configuration YAML correspondant est présenté en annexe à la figure [A.4](#).

Conclusion L'intégration des différentes ressources met en évidence la diversité des systèmes à protéger au sein d'une infrastructure distribuée. Les ressources intégrées sont segmentées selon des environnements distincts, notamment un environnement de développement et un environnement de production, dont les niveaux de sensibilité diffèrent. Cette distinction implique l'application de politiques d'accès différenciées afin de limiter l'exposition des ressources sensibles et de contrôler les privilèges accordés aux utilisateurs. La sous-section suivante présente la mise en place des politiques d'accès et des rôles d'utilisateur permettant d'assurer cette gouvernance.

2.3.3 Gouvernance des privilèges

La segmentation du plan de ressources nécessite la mise en place de politiques d'accès afin de protéger efficacement les ressources exposées. Cette section présente la définition des rôles et des règles d'autorisation permettant de contrôler l'accès aux ressources de chaque environnement, de limiter les privilèges accordés aux utilisateurs et de réduire les risques liés aux compromissions d'identité ou aux abus de privilèges. L'objectif est ainsi d'assurer un accès sécurisé et maîtrisé aux ressources de l'infrastructure.

2.3.3.1 Environnement de développement (env : dev)

L'environnement de développement regroupe le serveur **SSH-Sandbox** et la base de données **DB-Clients**, considérés comme des ressources destinées aux activités de développement et d'expérimentation.

Politiques d'accès : Dans le Plan de contrôle, l'accès à ces ressources est régi par le principe du moindre privilège, selon lequel les permissions sont attribuées aux utilisateurs en fonction de leurs responsabilités et des besoins strictement nécessaires à l'exécution de leurs tâches. Cette séparation des rôles permet de limiter les privilèges excessifs et d'assurer une gestion granulaire des accès aux ressources de l'environnement de développement. Dans cet environnement, deux rôles et trois utilisateurs sont définis :

- **admin** : attribué à l'utilisateur **bob**, ce rôle dispose de privilèges élevés permettant l'administration du serveur **SSH-Sandbox** ainsi que l'exécution d'opérations étendues sur la base de données **DB-Clients**.
- **role-standard** : attribué aux utilisateurs **alice** et **cedric**, ce rôle offre des permissions limitées, restreintes aux opérations courantes nécessaires aux activités de développement. Par conséquent, ces utilisateurs ne peuvent pas exécuter de commandes **sudo** ou des opérations SQL étendues.

Cette séparation des rôles permet de limiter l'octroi de privilèges excessifs. Les rôles définis, les utilisateurs concernés ainsi que les permissions associées sont synthétisés dans le tableau [2.3](#).

Rôle	Utilisateurs	SSH-Sandbox	DB-Clients	Responsabilités
admin	bob	accès administrateur	requêtes complètes	Administration des ressources
role-standard	alice, cedric	accès restreint	requêtes limitées	Exploitation courante

Tableau 2.3 – Politiques d'accès env : dev

La mise en œuvre de ces politiques d'accès passe par la configuration des rôles dans des fichiers YAML. Les figures 2.6 et 2.7 présentent les configurations des rôles **admin** et **role-standard** définis dans l'environnement de développement.

```
kind: role
version: v7
metadata:
  name: admin
spec:
  allow:
    logins:
      - osboxes
    node_labels:
      env: dev
    db_labels:
      env: dev
    db_names: ["DB-Clients"]
    db_users: ["teleport_writer"]
  options:
    max_sessions_ttl: 30m
  deny: {}
version: v7
```

Figure 2.6 – Fichier YAML du rôle admin

```
kind: role
version: v7
metadata:
  name: role-standard
spec:
  allow:
    logins:
      - user-guest
    node_labels:
      env: dev
    db_labels:
      env: dev
    db_names: ["DB-Clients"]
    db_users: ["teleport_reader"]
  options:
    max_sessions_ttl: 30m
  deny: {}
version: v7
```

Figure 2.7 – Fichier YAML du rôle role-standard

2.3.3.2 Environnement de production (env : prod)

Cet environnement regroupe le serveur **File-server** et l'application web **portail-marketing**, considérés comme des ressources sensibles nécessitant un niveau de protection plus élevé que celui de l'environnement de développement.

Politiques d'accès : Dans le Plan de contrôle, l'accès à ces ressources repose sur des politiques de contrôle plus strictes. Contrairement à l'environnement de développement, les privilèges élevés ne sont pas permanents. Ils sont accordés de manière temporaire selon un mécanisme d'élévation de privilèges contrôlé, afin de réduire l'exposition aux risques liés aux abus de privilèges. Dans cet environnement, trois rôles principaux sont définis :

- **Rôle marketing :** permet l'accès à l'application web **portail-marketing**. Il est attribué à l'utilisateur **jean** pour l'accès aux services applicatifs nécessaires à ses activités.
- **Rôle jit-request :** permet à un utilisateur de soumettre une demande d'élévation temporaire de privilèges.
- **Rôle jit-access :** accorde des privilèges élevés permettant l'accès au serveur **File-server** pour des opérations d'administration ou de maintenance. Ce rôle est attribué temporairement après validation d'une demande.

De ce fait, l'utilisateur **bob** dispose du rôle **jit-request**, lui permettant de solliciter un accès temporaire au rôle **jit-access** lorsque des opérations privilégiées sont requises sur le serveur de production. Les rôles définis, les utilisateurs concernés ainsi que les permissions associées sont synthétisés dans le tableau 2.4.

Rôle	Utilisateurs	Ressources associées	Permissions principales
marketing	jean	portail-marketing	Accès à l'application web
jit-request	bob	Demande d'accès privilégié au serveur File-server	Demande de privilèges temporaires
jit-access	Accès temporaire	File-server	Accès privilégié pour opérations d'administration/maintenance

Tableau 2.4 – Politiques d'accès env : prod

Les figures 2.8, 2.9 et 2.10 présentent les fichiers de configuration des différents rôles.

```
kind: role
version: v7
metadata:
  name: jit-request
spec:
  allow:
    request:
      roles: [jit-access]
  deny: {}
```

Figure 2.8 – Fichier YAML du rôle jit-request

```
kind: role
version: v7
metadata:
  name: jit-access
spec:
  allow:
    logins:
      - admin
    node_labels:
      role: file_server
  options:
    disconnect_expired_cert: yes
    max_session_ttl: 30m
```

Figure 2.9 – Fichier YAML du rôle jit-access

```
kind: role
version: v7
metadata:
  name: marketing
spec:
  allow:
    app_labels:
      env: prod
      team: marketing
  options:
    max_session_ttl: 2h0m0s
  deny: {}
version: v7
```

Figure 2.10 – Fichier YAML du rôle marketing

2.4 Tests de validation

Cette section présente les tests réalisés afin de valider les mécanismes de sécurisation des accès mis en œuvre par l'architecture. Chaque test vise à valider un objectif spécifique de ce travail.

2.4.1 Centralisation de l'accès aux ressources

L'objectif est de vérifier que l'accès aux ressources est centralisé via une plateforme unique et qu'aucun accès direct aux ressources n'est possible en dehors de celle-ci.

Test 1 : Accès aux ressources via la plateforme

Objectif : Vérifier que l'accès aux ressources s'effectue exclusivement via le plan de contrôle, notamment à travers le service proxy.

Procédure 1 : flux de connexion de l'utilisateur **bob** aux ressources via la plateforme

Flux d'accès aux ressources via la plateforme

```
# Authentification
$ tsh login --user=bob --proxy=teleport:3080 --insecure

# Vérification des ressources accessibles
$ tsh ls & tsh db ls

# Ouverture d'une session SSH vers SSH-Sandbox
$ tsh ssh osboxes@SSH-Sandbox

# Accès à la base de données via le proxy
$ tsh db connect DB-Clients --db-user=teleport_writer
--proxy=teleport:3080 --insecure
```

Procédure 2 : Accès à l'application web via l'interface web

- Authentification de **jean** sur Teleport
- Accès au **portail-marketing** via l'interface Web

Résultat attendu : Les connexions au serveur SSH, à la base de données et à l'application web sont établies via le plan de contrôle après authentification, ce qui confirme qu'il constitue le point d'accès central aux ressources.

Test 2 : Tentative d'accès direct aux ressources

L'objectif est de vérifier que les ressources ne sont pas accessibles directement sans passer par le plan de contrôle. Pour cela, un utilisateur tente de se connecter directement :

- Au serveur **SSH-Sandbox** avec la commande SSH classique : la tentative échoue ;
- A la base de données **DB-Clients** avec la commande `mysql -h 192.168.1.69 -u teleport_reader -p` : la tentative échoue.

2.4.2 Segmentation des ressources

L'objectif est de vérifier que la visibilité des ressources dépend des rôles attribués aux utilisateurs. Un utilisateur associé à l'environnement de développement ne voit pas les ressources de l'environnement de production et inversement.

Procédure :

- Consultation de l'onglet **Resources** de l'utilisateur **alice**
- Consultation de l'onglet **Resources** de l'utilisateur **jean**

Résultat attendu :

L'utilisateur **alice** voit uniquement les ressources associées à l'environnement de développement, à savoir : le serveur **SSH-Sandbox** et la base de données **DB-Clients**. Tandis que l'utilisateur **jean** n'a accès qu'à l'application web.

2.4.3 Gouvernance des privilèges (RBAC et JIT)

L'objectif est de vérifier que les politiques d'accès définies pour chaque environnement sont bien appliquées.

2.4.3.1 Validation des politiques d'accès (env : dev)

Le tableau 2.5 présente les tests de connexion aux ressources de l'environnement de développement.

Tests	Objectifs	Procédure	Résultats attendus
Test 1	Vérifier que les privilèges système accordés sur le serveur dépendent du rôle attribué	• Connexion de bob au serveur SSH et exécution de commandes sudo ; • Connexion de alice au serveur SSH et exécution de commandes sudo.	• Utilisateur bob : Commandes sudo autorisées ; • Utilisateur alice : Commandes sudo refusées.
Test 2	Vérifier que les permissions sur la base de données dépendent du rôle attribué	• Utilisateur bob : exécution de requêtes INSERT et UPDATE ; • Utilisateur cedric : exécution de requêtes INSERT.	• Utilisateur bob : opérations autorisées ; • Utilisateur cedric : opérations refusées.

Tableau 2.5 – Validation des politiques d'accès (env : dev)

2.4.3.2 Validation des politiques d'accès (env : prod)

L'objectif est de vérifier que l'accès aux ressources sensibles avec des privilèges élevés n'est accordé que temporairement, via un processus d'approbation.

Test : Élévation temporaire de privilèges (JIT)

Procédure :

L'utilisateur **bob** soumet une demande d'accès pour accéder au **File-server** avec des privilèges élevés afin d'effectuer une opération de maintenance rapide.

Requête d'accès juste-à-temps

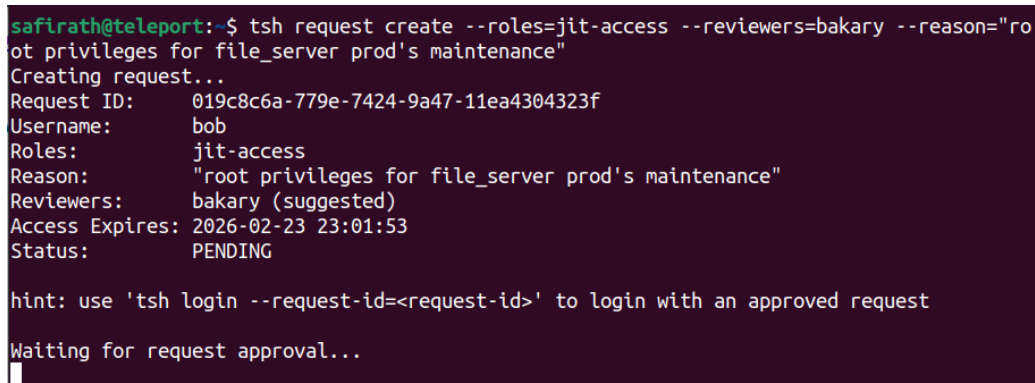
```
# Création d'une requête d'accès
$ tsh request create --roles=jit-access --reviewers=bakary --reason="root privilege for File-server prod maintenance"

# Approbation de la requête par un administrateur
$ sudo tctl request ls
$ sudo tctl request approve --roles="jit-access" --reason="approved"
<request_id>
```

Résultats attendus :

- accès accordé uniquement après approbation ;
- durée limitée à 30 minutes ;
- révocation automatique des privilèges à l'expiration du délai.

La figure 2.11 montre la requête créée en attente d'approbation.



```
safirath@teleport:~$ tsh request create --roles=jit-access --reviewers=bakary --reason="root privileges for file_server prod's maintenance"
Creating request...
Request ID:      019c8c6a-779e-7424-9a47-11ea4304323f
Username:       bob
Roles:          jit-access
Reason:         "root privileges for file_server prod's maintenance"
Reviewers:      bakary (suggested)
Access Expires: 2026-02-23 23:01:53
Status:         PENDING

hint: use 'tsh login --request-id=<request-id>' to login with an approved request

Waiting for request approval...
```

Figure 2.11 – Requête en attente d'approbation

2.4.4 Sécurité des communications et de l'authentification

Cette sous-section vise à valider les mécanismes de sécurisation des communications et de l'authentification au sein de l'architecture. L'objectif est de vérifier que les certificats émis aux utilisateurs sont temporaires, que les communications sont chiffrées et que l'authentification des utilisateurs est renforcée par le MFA.

Test 1 : Utilisation des certificats éphémères et chiffrement des données

Il s'agit de vérifier que les sessions des utilisateurs reposent sur des certificats temporaires possédant une durée de validité limitée et que les communications sont chiffrées par le protocole TLS.

Procédure :**Inspection de certificat de session**

Inspection du certificat généré localement

```
$ openssl x509 -in ~/.tsh/keys/teleport/alice.crt -text -noout
```

Capture du trafic lors de l'authentification

```
$ sudo tcpdump -i any -w mtls.pcap port 3080
```

- Consultation d'un rôle afin de vérifier les paramètres : **max_session_ttl** et **disconnect_expired_cert**

Résultats attendus :

- certificat avec une durée de validité limitée (Valid until) ;
- présence d'échanges TLS (Client Hello, Server Hello) ;
- données applicatives chiffrées.

Test 2 : Validation de l'authentification multifacteur

L'objectif est de vérifier que l'authentification des utilisateurs requiert un second facteur de vérification en complément du mot de passe.

Procédure :

- Connexion d'un utilisateur à la plateforme ;
- Observation de la mire d'authentification.

Résultat attendu : exigence d'un second facteur lors de la connexion

2.4.5 Audit et traçabilité

Cette sous-section vise à vérifier la capacité du plan de contrôle à enregistrer et tracer les actions réalisées par les utilisateurs lors de l'accès aux ressources. L'objectif est de démontrer que toutes les opérations sont associées à une identité précise, que les événements sont journalisés et que les sessions peuvent être rejouées à des fins d'audit. Le tableau [2.6](#) résume les tests réalisés.

Tests	Objectifs	Procédure	Résultats attendus
Consultation des logs d'activités	Vérifier que les activités des utilisateurs sont enregistrées et consultables	Consultation des logs depuis l'onglet Audit log de l'interface web	• Enregistrement des événements d'accès et des actions effectuées ; • Association explicite de chaque action à l'identité de l'utilisateur.
Traçabilité dans un scénario de comptes partagés	Vérifier que l'audit reste basé sur l'identité réelle de l'utilisateur même avec l'utilisation de comptes système communs	• Connexion des utilisateurs alice et cedric disposant du même rôle et spécifiant un compte système commun ; • Consultation des journaux d'audit.	La traçabilité est associée à l'identité individuelle de chaque utilisateur
Relecture des sessions enregistrées	Vérifier que les sessions peuvent être enregistrées et rejouées à des fins d'audit	Consultation de l'onglet Session recordings de l'interface Web	Sessions SSH enregistrées et rejouables, avec la possibilité d'analyser les commandes exécutées durant la session.

Tableau 2.6 – Tests de validation de la traçabilité

Conclusion

Ce chapitre a présenté l'architecture centralisée et sécurisée conçue pour la gestion des accès à différents types de ressources, en détaillant ses principes techniques et sa mise en œuvre à l'aide de la solution Teleport. L'intégration des ressources (serveurs SSH, base de données et application web), la configuration des politiques d'accès et la mise en place des mécanismes de sécurité et de traçabilité ont permis de mettre en œuvre l'architecture proposée. Des tests de validation ont ensuite été réalisés afin de vérifier l'atteinte des objectifs fixés. Le chapitre suivant est consacré à la présentation et à l'analyse des résultats obtenus.

Résultats

Introduction

Ce chapitre présente et analyse les résultats obtenus à l'issue des tests de validation.

3.1 Résultat de la centralisation de l'accès aux ressources

La figure 3.1 présente l'onglet **Resources** de l'interface Web. d'administration de Teleport

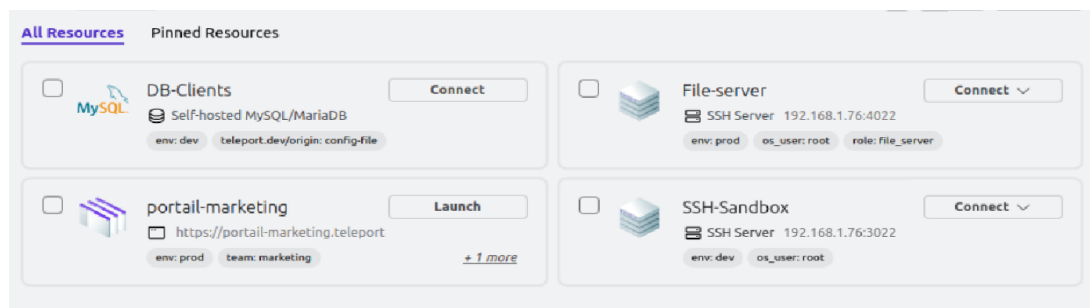


Figure 3.1 – Centralisation des ressources

Cette interface montre que les serveurs SSH, la base de données MySQL et l'application Web intégrés sont regroupés au sein d'un point d'accès unique. Cela confirme que les ressources de l'architecture sont centralisées dans un plan de contrôle commun, permettant leur gestion depuis une seule interface.

Les figures 3.2, 3.3 et 3.4 présentent respectivement les flux de connexion de l'utilisateur **bob** aux ressources **SSH-Sandbox** et **DB-Clients**, ainsi que celui de l'utilisateur **jean** à Web via la plateforme.

```
safirath@teleport:~$ tsh login --proxy=teleport:3080 --user=bob --insecure
Enter password for Teleport user bob:
WARNING: You are using insecure connection to Teleport proxy https://teleport:3080
Enter an OTP code from a device:
> Profile URL:      https://teleport:3080
  Logged in as:     bob
  Cluster:          teleport
  Roles:             admin, jit-request
  Logins:            osboxes
  Kubernetes:        enabled
  Valid until:       2026-03-01 18:35:13 +0100 WAT [valid for 3h0m0s]
  Extensions:        login-ip, permit-port-forwarding, permit-pty, private-key-policy

safirath@teleport:~$ tsh ls
Node Name  Address          Labels
-----
SSH-Sandbox 192.168.1.83:3022 env=dev,os_user=root

safirath@teleport:~$ tsh db ls
Name      Description Allowed Users  Labels  Connect
-----
DB-Clients [teleport_writer] env=dev

safirath@teleport:~$ tsh ssh osboxes@SSH-Sandbox
osboxes@Application:~$ ls
Bureau Documents Images Musique run Téléchargements
cmds  get-docker.sh key      prod-cluster-values.yaml secure_access Vidéos
-d    -H      Modèles Public      snap

osboxes@Application:~$
```

Figure 3.2 – Accès au serveur SSH-Sandbox

```
safirath@teleport:~$ tsh db connect DB-Clients --db-user=teleport_writer --proxy=teleport:3080 --insecure
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 10002
Server version: 8.0.45-0ubuntu0.22.04.1 (Ubuntu)

Copyright (c) 2000, 2026, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> Use DB-Clients;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql>
```

Figure 3.3 – Accès à la base de données DB-Clients

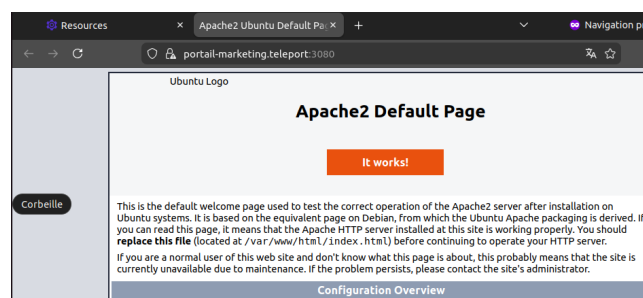


Figure 3.4 – Accès au portail-marketing

Ces résultats montrent que toutes les ressources sont accessibles uniquement après authentification sur la plateforme et que les connexions transitent par le **proxy_service**. Cela signifie que l'accès aux différentes ressources est centralisé autour de la plateforme, qui constitue le point d'entrée unique.

Les figures 3.5 et 3.6 présentent respectivement une tentative d'accès direct au serveur SSH et à la base de données sans passer par la plateforme.

```
safirath@teleport:~$ ssh user-guest@192.168.1.76
ssh: connect to host 192.168.1.76 port 22: Connection timed out
safirath@teleport:~$
```

Figure 3.5 – Tentative d'accès direct au serveur SSH-Sandbox

```
osboxes@Application:~$ mysql -h 192.168.1.69 -u teleport_reader -p
Enter password:
ERROR 1045 (28000): Access denied for user 'teleport_reader'@'192.168.1.83' (using password: NO)
```

Figure 3.6 – Tentative d'accès direct à la base de données

L'échec de ces connexions montre que les ressources ne sont pas directement exposées sur le réseau et que leur accès nécessite de passer par le plan de contrôle.

Apport de la centralisation : S'appuyer sur une architecture centralisée des accès permet de remédier à l'administration dispersée des ressources et d'en simplifier la gestion via un point de contrôle unique.

3.2 Résultat de la segmentation des ressources

Les figures 3.7 et 3.8 présentent respectivement l'onglet **Resources** de l'utilisateur **alice** et celui de l'utilisateur **jean** dans l'interface Web de Teleport.

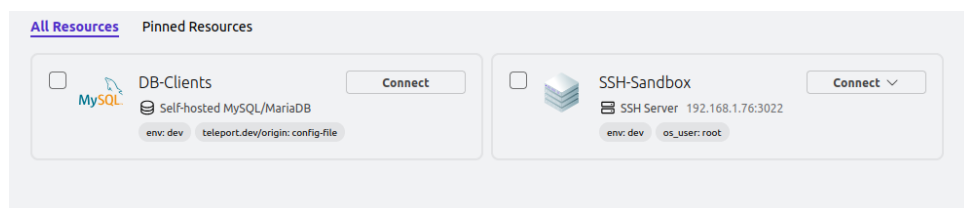


Figure 3.7 – Onglet "Resources" de alice

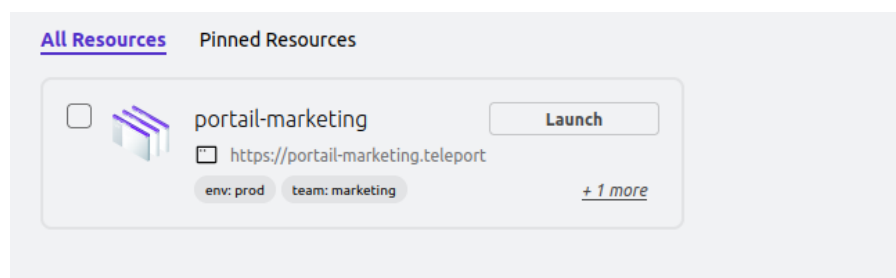


Figure 3.8 – Onglet "Resources" de jean

On constate que, grâce aux labels définis (**env : dev**, **env : prod**), chaque utilisateur n'accède qu'aux ressources correspondant à son périmètre d'autorisation. Cette restriction confirme la mise en œuvre de la segmentation, qui limite la visibilité et l'accès aux ressources selon des critères prédéfinis.

Apport de la segmentation : La segmentation des ressources est essentielle pour limiter la propagation des risques et garantir que chaque environnement reste isolé en cas de compromission. Elle permet d'appliquer des politiques de sécurité adaptées à la sensibilité des ressources et réduit les risques liés aux accès excessifs.

3.3 Résultat de la Gouvernance des privilèges (RBAC et JIT)

3.3.1 Environnement de développement

Les figures 3.9 et 3.10 présentent respectivement les sessions de l'utilisateur **bob** sur le serveur **SSH-Sandbox** et sur la base de données **DB-Clients**.

```
safirath@teleport:~$ tsh ssh osboxes@SSH-Sandbox
osboxes@Application:~$ sudo visudo
[sudo] Mot de passe de osboxes :
visudo: /etc/sudoers.tmp n'a pas été modifié
osboxes@Application:~$ sudo su -
root@Application:~# exit
logout
osboxes@Application:~$ sudo dmesg | head -n 3
[ 0.000000] Linux version 6.8.0-94-generic (buildd@lcy02-amd64-114) (x86_64-linux-gnu-gcc-12 (Ubuntu 12.3.0-1ubuntu1~22.04.2) 12.3.0, GNU ld (GNU Binutils for Ubuntu) 2.38) #96~22.04.1-Ubuntu SMP PREEMPT_DYNAMIC Fri Jan 16 13:19:05 UTC 2
(Ubuntu 6.8.0-94.96~22.04.1-generic 6.8.12)
[ 0.000000] Command line: BOOT_IMAGE=/vmlinuz-6.8.0-94-generic root=UUID=b67edd03-5aa9-4826-add9-3de240b4c108 ro quiet splash
[ 0.000000] KERNEL supported cpus:
osboxes@Application:~$
```

Figure 3.9 – Session de bob sur SSH-Sandbox

```
mysql> Use DB-Clients;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> INSERT INTO accounts (username) VALUES ('anita');
Query OK, 1 row affected (0,02 sec)

mysql> SELECT * FROM accounts;
+-----+
| username |
+-----+
| anita    |
+-----+
1 row in set (0,00 sec)

mysql> UPDATE accounts SET username = 'anita_codjo' WHERE username = 'anita';
Query OK, 1 row affected (0,01 sec)
Rows matched: 1 Changed: 1 Warnings: 0

mysql>
```

Figure 3.10 – Session de bob sur DB-Clients

On constate que, conformément au rôle **admin** qu'il possède, il peut exécuter des commandes **sudo** et effectuer des opérations Structured Query Language (SQL) étendues.

Les figures 3.9 et 3.10 présentent respectivement la session SSH de l'utilisateur **alice** depuis l'interface web et la session de l'utilisateur **cedric** sur la base de données depuis la Command Line Interface (CLI).

```

user-guest@SSH-Sandbox X +
user-guest@Application:~$ sudo visudo
[sudo] Mot de passe de user-guest :
user-guest n'apparaît pas dans le fichier sudoers. Cet incident sera signalé.
user-guest@Application:~$ sudo su -
[sudo] Mot de passe de user-guest :
user-guest n'apparaît pas dans le fichier sudoers. Cet incident sera signalé.
user-guest@Application:~$ sudo dmesg | head -n 3
[sudo] Mot de passe de user-guest :
user-guest n'apparaît pas dans le fichier sudoers. Cet incident sera signalé.
user-guest@Application:~$ ls
user-guest@Application:~$

```

Figure 3.11 – Session de alice sur SSH-Sandbox

```

mysql> Use DB-Clients;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> SELECT * FROM accounts;
+-----+
| username |
+-----+
| anita_codjo |
+-----+
1 row in set (0,00 sec)

mysql> INSERT INTO accounts (username) VALUES ('safrath');
mysql> ERROR 1142 (42000): INSERT command denied to user 'teleport_reader'@'192.168.1.77' for table 'accounts'
Afficher les applications
mysql>

```

Figure 3.12 – Session de cedric sur DB-Clients

On observe que, conformément au rôle commun **role-standard** qu'ils possèdent, leurs actions sont limitées à des opérations simples.

3.3.2 Environnement de production

La figure 3.13 montre la réception de l'approbation de la requête d'accès soumise par l'utilisateur **bob**, suivie de l'ouverture d'une session sur le serveur **File-server**. On observe la mise à jour des certificats de session ainsi que l'octroi temporaire du rôle demandé.

```

Approval received, reason="approved"
Getting updated certificates...

> Profile URL:      https://teleport:3080
  Logged in as:     bob
  Active requests:  019c8c6a-779e-7424-9a47-11ea304323f
  Cluster:          teleport
  Roles:            admin, jit-access, jit-request
  Logins:           osboxes, admin
  Kubernetes:       enabled
  Valid until:      2026-02-23 23:01:53 +0100 WAT [valid for 28m0s]
  Extensions:       login-ip, permit-port-forwarding, permit-pty, private-key-policy

safrath@teleport:~$ tsh ls
Node Name  Address  Labels
-----
File-server 192.168.1.76:4022 env=prod,os_user=root,role=file_server

safrath@teleport:~$ tsh ssh admin@File-server
admin@Application:~$ cd /
admin@Application:~$ ls
bin      cdrom  home  lib64  media  proc  sbin  sys  var
boot     dev    lib   lib32  mnt    root  snap  tmp  workers.hcl
boundaryd.hcl etc    lib32 lost+found opt    run   srv   usr
admin@Application:~$

```

Figure 3.13 – Requête d'accès juste-à-temps approuvé

La figure 3.14 montre l'expiration de la durée d'accès accordée. On constate qu'après l'expiration des 30 minutes, les certificats deviennent invalides et la session est automatiquement interrompue, entraînant la révocation des privilèges temporaires accordés.

```

admin@Application:/etc$ cd /
admin@Application:/ $ ls
bin    boundaryd.hcl  dev  home  lib32  libx32  media  opt  root  sbin  srv  tmp  var
boot  cdrom          etc  lib   lib64  lost+found  mnt   proc  run  snap  sys  usr  workers.hcl
admin@Application:/ $ client certificate expired at 2026-02-23 22:01:53.00070438 +0000 UTCERROR: wait: remote command exi
ted without exit status or exit signal
safirath@teleport:~$

```

Figure 3.14 – Révocation des privilèges accordés

Apport de la gouvernance des privilèges : La mise en œuvre du contrôle d'accès basé sur les rôles (RBAC), combinée au mécanisme d'élévation de privilèges (JIT) et au principe du moindre privilège, permet d'assurer une gouvernance dynamique des accès aux ressources. Cette approche limite l'octroi de privilèges excessifs et élevés et garantit que les droits accordés aux utilisateurs sont strictement alignés avec leurs responsabilités. Elle renforce ainsi la sécurité globale de l'architecture en maîtrisant l'accès aux ressources sensibles.

3.4 Résultat de la sécurité des communications et de l'authentification

La figure 3.15 présente le certificat de session associé à l'utilisateur **alice**. On observe le champ **Validity** (Not Before / Not After) qui indique la durée de validité du certificat, ainsi que le **Common Name (CN)** correspondant à l'identité de l'utilisateur. Ces éléments démontrent l'utilisation de certificats éphémères liés à l'identité de chaque utilisateur.

```

safirath@teleport:/etc$ openssl x509 -in /home/safirath/.tsh/keys/teleport/alice
.crt -text -noout
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            b1:9e:28:13:76:77:2c:0a:64:0d:09:f2:fa:94:f9:03
        Signature Algorithm: ecdsa-with-SHA256
        Issuer: O = teleport, CN = teleport, serialNumber = 24955668107155246585
0177015802316619031
        Validity
            Not Before: Feb 25 14:25:18 2026 GMT
            Not After : Feb 25 17:26:18 2026 GMT
        Subject: L = user-guest + L = -teleport-internal-join, street = teleport
, postalCode = {"logins":["alice"]}, O = role-standard, CN = alice, 1.3.9999
.1.7 = teleport, 1.3.9999.1.9 = 127.0.0.1, 1.3.9999.2.5 = DB-Clients, 1.3.9999.2
.6 = teleport_reader, 1.3.9999.1.20 = local, 1.3.9999.1.15 = none

```

Figure 3.15 – Certificat éphémère de l'utilisateur alice

La figure 3.16 renforce la preuve du certificat éphémère. Elle montre les paramètres **max_session_ttl** et **disconnect_expired_cert** configurés dans un rôle depuis l'interface d'administration. Le **max_session_ttl** définit une durée de validité pour les sessions et **disconnect_expired_cert** assure l'interruption automatique des sessions à l'expiration de ce délai. Cela impose une ré-authentification régulière et réduit les risques liés à l'utilisation prolongée des certificats.

GLOBAL SETTINGS

Max Session TTL: 3h0m0s

Client Idle Timeout:

Disconnect When Certificate Expires: ☒ True ☐ False

Require Session MFA: No

Default Session Recording Mode: Best Effort

Save Changes

Figure 3.16 – Paramètres max_session_ttl et disconnect_expired_cert

La figure 3.17 présente la capture du trafic réseau lors de l'authentification (**tsh login**). On observe les échanges Client Hello et Server Hello, suivis de données applicatives chiffrées (Encrypted Application Data) avec le protocole TLSv1.3. Ces éléments confirment que les échanges entre les composants sont chiffrés.

No.	Time	Source	Destination	Protocol	Length	Info
6	8.957525	127.0.0.1	127.0.0.1	TLSv1.3	1536	Client Hello
8	8.958667	127.0.0.1	127.0.0.1	TLSv1.3	2294	Server Hello, Change Cipher Spec, Application Data
10	8.959453	127.0.0.1	127.0.0.1	TLSv1.3	160	Change Cipher Spec, Application Data, Application Data
11	8.959548	127.0.0.1	127.0.0.1	TLSv1.3	193	Application Data
13	8.986461	127.0.0.1	127.0.0.1	TLSv1.3	1274	Application Data
14	8.986495	127.0.0.1	127.0.0.1	TLSv1.3	198	Application Data
16	8.987812	127.0.0.1	127.0.0.1	TLSv1.3	90	Application Data
18	8.988081	127.0.0.1	127.0.0.1	TLSv1.3	90	Application Data
23	8.989442	127.0.0.1	127.0.0.1	TLSv1.3	1565	Client Hello
25	8.990676	127.0.0.1	127.0.0.1	TLSv1.3	2323	Server Hello, Change Cipher Spec, Application Data
27	8.991330	127.0.0.1	127.0.0.1	TLSv1.3	160	Change Cipher Spec, Application Data, Application Data
28	8.991390	127.0.0.1	127.0.0.1	TLSv1.3	90	Application Data
34	8.992396	127.0.0.1	127.0.0.1	TLSv1.3	1536	Client Hello
36	8.993527	127.0.0.1	127.0.0.1	TLSv1.3	2293	Server Hello, Change Cipher Spec, Application Data
38	8.994544	127.0.0.1	127.0.0.1	TLSv1.3	160	Change Cipher Spec, Application Data, Application Data
39	8.994809	127.0.0.1	127.0.0.1	TLSv1.3	193	Application Data
41	8.995620	127.0.0.1	127.0.0.1	TLSv1.3	1274	Application Data

TLSv1.3 Record Layer: Application Data Protocol: Application Data
 Opaque Type: Application Data (23)
 Version: TLS 1.2 (0x0303)
 Length: 19
 Encrypted Application Data: 27352f971165b6debe6407a84b13bfa6e19188

Figure 3.17 – Trafic capturé

Enfin, la figure 3.18 présente la mire d'authentification qui s'affiche lors de la connexion à la plateforme. Un second facteur d'authentification est demandé en plus du mot de passe de l'utilisateur.

Sign in to Teleport

Username:

Password:

Multi-factor Type: Authenticator Code:

Sign In

Figure 3.18 – Authentification multifacteur (MFA)

Apport de la sécurisation des connexions : Ces résultats montrent que le plan de contrôle intègre des mécanismes pour sécuriser les communications et l'authentification. Ces mécanismes reposent sur l'utilisation de certificats éphémères, le chiffrement des échanges et l'authentification multifacteur. Cette approche renforce la protection des identités et des sessions et limite les risques liés au vol d'identifiants.

3.5 Résultat de l'audit et de la traçabilité

La figure 3.19 présente dans l'onglet **Audit log** de la plateforme plusieurs journaux d'activités associés aux différents utilisateurs. On constate que les actions effectuées (ouvertures de session, authentification, déconnexion) sont enregistrées et rattachées à l'identité de chaque utilisateur. Ces éléments confirment la traçabilité et la possibilité de consulter l'historique des actions effectuées.

	Certificate Issued	User certificate issued for [bakary]	2026-02-25T14:31:58.713Z	Details
	Session Uploaded	Recorded session [8570d40b-0c04-4b00-8bb5-4a9a8aecdf47] has been uploaded	2026-02-25T14:26:51.248Z	Details
	Certificate Issued	User certificate issued for [alice]	2026-02-25T14:26:18.582Z	Details
	Local Login	Local user [alice] successfully logged in	2026-02-25T14:26:18.580Z	Details
	MFA Authentication Attempt	User [alice] requested an MFA authentication challenge	2026-02-25T14:26:02.612Z	Details
	Certificate Issued	User certificate issued for [bakary]	2026-02-25T14:24:57.867Z	Details
	App Session Data	New session data chunk created for application [portal-marketing] accessed by user [bakary]	2026-02-25T14:21:47.145Z	Details
	App Session Started	User [bakary] has connected to application [portal-marketing]	2026-02-25T14:21:46.923Z	Details
	Certificate Issued	User certificate issued for [bakary]	2026-02-25T14:21:46.901Z	Details

Figure 3.19 – Journaux d'activités

Ensuite, la figure 3.20 présente les journaux d'activité enregistrés dans l'onglet **Audit log** à la suite du scénario de comptes partagés. Elle montre distinctement les ouvertures de session des utilisateurs **alice** et **bob** sur le serveur **SSH-Sandbox**. On constate que chaque log est associé à une identité spécifique, même lorsque les utilisateurs accèdent au serveur SSH avec le même compte système. C'est la preuve que l'audit reste lié à l'identité individuelle de chaque utilisateur et permet d'identifier précisément l'origine des actions effectuées.

	Session Started	User [alice] has started a session [a4abf318-4e41-4b0d-aac2-a7370dcc7d1b] on node [SSH-Sandbox]	2026-02-25T15:13:32.651Z	Details
	Session Started	User [cedric] has started a session [1a4382ae-bcc8-415a-abcb-d156d682503b] on node [SSH-Sandbox]	2026-02-25T15:12:08.682Z	Details

Figure 3.20 – Logs du scénario de comptes partagés

Enfin, la figure 3.21 présente des sessions SSH enregistrées depuis l'onglet **Session recordings**. On constate que ces sessions peuvent être rejouées et que les commandes exécutées durant celles-ci

peuvent être analysées, comme le montre la figure 3.22. Cette fonctionnalité permet de vérifier les actions réalisées sur les ressources et facilite les activités de supervision.

Type	Name	User(s)	Duration	Created (UTC)	Session ID	
>_	SSH-Sandbox	cedric	3 minutes	2026-02-25T15:14:46.633Z	1a4382ae-bcc8-415a-abcb-d156d682503b	<button>Play</button>
>_	SSH-Sandbox	alice	1 minute	2026-02-25T15:14:39.732Z	a4abf318-4e41-4b0d-aac2-a7370dcc7d1b	<button>Play</button>

Figure 3.21 – Enregistrement de sessions ssh

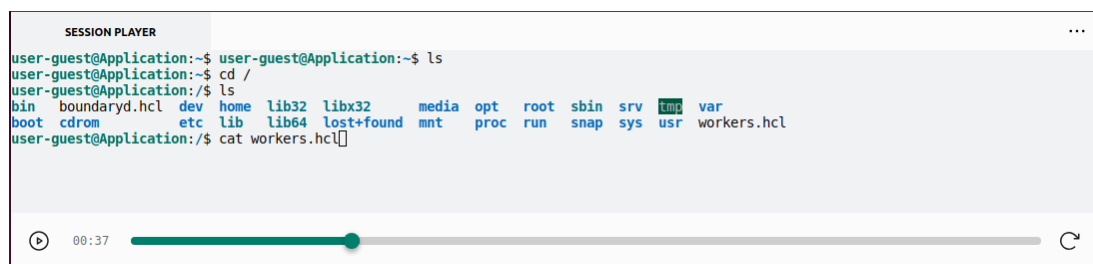


Figure 3.22 – Replay de session ssh

Apport de l’audit et de la traçabilité : Ces résultats démontrent que la plateforme assure une traçabilité complète des actions réalisées sur les ressources de l’infrastructure. L’enregistrement des activités, l’association de chaque action à l’identité des utilisateurs et la relecture des sessions renforcent les capacités d’audit, de supervision et de responsabilisation des utilisateurs.

3.6 Analyse des résultats obtenus

Afin de démontrer l’apport de l’architecture mise en œuvre face aux enjeux de gestion des accès identifiés dans l’introduction, le tableau 3.1 fait correspondre les principaux défis de sécurité et les mécanismes déployés pour y répondre.

Enjeux de gestion des accès	Réponse apportée par l'architecture mise en œuvre
Administration dispersée des accès dans une infrastructure distribuée	Centralisation des accès via un point de contrôle unique regroupant l'ensemble des ressources
Exposition excessive des ressources et nécessité de protéger les ressources sensibles	Segmentation des ressources par environnement et application de politiques d'accès adaptées
Attribution excessive de privilèges, gestion insuffisante des comptes privilégiés et risques d'abus	Gouvernance des accès par la mise en œuvre du RBAC basé sur le principe du moindre privilège et du mécanisme Just-In-Time pour l'élévation temporaire des privilèges
Risques liés à la sécurité des connexions et de l'authentification (Vols d'identifiants, mots de passe faible...)	Utilisation de certificats éphémères, authentification multifacteur et chiffrement des communications
Traçabilité peu centralisée, manque de visibilité sur les actions des utilisateurs et difficulté d'investigation	Journalisation complète des actions liés à l'identité individuelle des utilisateurs, enregistrement et relecture des sessions et centralisation des logs

Tableau 3.1 – Enjeux de gestion des accès vs réponses apportées

3.7 Discussion

Cette section présente les limites identifiées lors de la mise en œuvre de la solution, ainsi que les perspectives d'évolution envisageables afin d'améliorer le travail.

Limites de l'environnement de déploiement

- Déploiement en local, sans mécanisme de haute disponibilité : l'Auth Service et le Proxy constituent des points de défaillance uniques non représentatifs d'un déploiement en production ;
- Utilisation de certificats auto-signés en lieu et place d'une autorité de certification reconnue ;
- Infrastructure simulée à échelle réduite : nombre limité d'utilisateurs et de ressources ne permettant pas de valider le comportement de l'architecture sous des conditions réelles d'exploitation (charge, utilisateurs simultanés, contraintes réseau) ;
- Logs stockés localement sur la machine hébergeant l'Auth Service.

Limites de la version open-source de Teleport

Limites fonctionnelles

- **Single Sign-On (SSO) et fédération d'identité** : prise en charge exclusive de GitHub comme fournisseur d'identité ; ne prend pas en charge les principaux services d'entreprise (Google Workspace, Microsoft Entra ID, Okta) ;
- **Automatisation du JIT** : les demandes et validations d'accès reposent sur des actions manuelles, réalisées uniquement via la ligne de commande ;
- **Fonctionnalités d'audit restreintes** : Absence de relecture interactive des sessions de bases de données ;
- **Support Windows limité** : gestion restreinte des environnements Windows.

Contraintes de déploiement en environnement réel

- **Scalabilité et Haute disponibilité** : non automatisé, impliquant des configurations externes et une forte intervention de l'administrateur ;
- **Complexité de l'auto-hébergement** : déploiement, sécurisation et exploitation du cluster nécessitant une expertise avancée ;
- **Charge opérationnelle élevée** : maintenance, mises à jour et supervision réalisées sans support officiel ;
- **Coûts indirects et Restriction d'usage** : malgré la gratuité de la licence, les coûts indirects peuvent être significatifs ; l'usage est en outre limité aux organisations de moins de 100 employés réalisant moins de 10 millions de dollars de chiffre d'affaires annuel.

Limites en matière de conformité

- **Absence de conformité aux standards Federal Risk and Authorization Management Program (FedRAMP) et Federal Information Processing Standards (FIPS)** : Teleport Community Edition (CE) ne répond pas aux exigences des cadres réglementaires fédéraux tels que FedRAMP ni aux normes cryptographiques FIPS ;
- **Conformité limitée aux cadres réglementaires et normatifs majeurs** : Teleport CE ne fournit pas l'ensemble des garanties attendues pour répondre pleinement aux exigences des normes et réglementations telles que Digital Operational Resilience Act (DORA), Sarbanes-Oxley Act (SOX), ISO 27001, Network and Information Security Directive 2 (NIS2), PCI-DSS, SOC 2, Health Insurance Portability and Accountability Act (HIPAA) ou encore NIST.

Perspectives d'évolution

- Export des logs vers un Security Information and Event Management (SIEM) pour la corrélation et l'envoi d'alertes (ex. Splunk) ;
- Extension de l'architecture à d'autres types de ressources (Windows/RDP, Kubernetes, ...) ;
- Déploiement en environnement de production afin d'assurer :
 - haute disponibilité ;

- automatisation du workflow JIT (Jira, Slack) avec la version Enterprise ;
- intégration d'un Identity Provider (IdP) externe (ex. Keycloak, Okta, Google Workspace) avec la version Enterprise ;
- gestion des certificats par une autorité reconnue.

Conclusion

Ce chapitre a permis de présenter et d'analyser les résultats issus des tests de validation réalisés. Les observations faites confirment l'atteinte des objectifs fixés, notamment en matière de centralisation des accès, de segmentation des ressources, de gouvernance des privilèges, de sécurisation des communications et de traçabilité des actions. L'analyse met également en évidence l'apport des mécanismes de sécurisation de l'architecture face aux enjeux de gestion des accès identifiés. Une discussion a permis de relever les limites liées à l'environnement de déploiement ainsi qu'aux contraintes fonctionnelles de la version Community Edition de Teleport utilisée pour la mise en œuvre. Des perspectives sont enfin proposées pour ce travail.

Conclusion Générale et perspectives

La gestion des accès aux ressources informatiques constitue aujourd'hui un enjeu majeur pour les organisations, dans un contexte marqué par la complexité croissante des infrastructures numériques, la multiplication des menaces liées aux identités et aux comptes privilégiés, ainsi que les limites des approches traditionnelles de contrôle d'accès. Face à ces défis, les organisations doivent mettre en place des mécanismes de sécurité capables de garantir un accès contrôlé, traçable et adapté à leurs besoins réels, tout en assurant la protection des ressources sensibles au sein d'environnements distribués. Ce travail s'est inscrit dans la problématique de la centralisation et de la sécurisation des accès dans une infrastructure distribuée, tout en garantissant la traçabilité des actions. Pour répondre à cette problématique, il s'appuie sur la solution open source Teleport afin de mettre en œuvre une architecture centralisée et sécurisée de gestion des accès aux ressources, adaptée à une infrastructure distribuée. Les résultats obtenus confirment l'atteinte des objectifs fixés, prouvant que l'architecture proposée répond aux enjeux de centralisation des accès, de protection des ressources sensibles, de gouvernance des privilèges à travers les mécanismes de contrôle d'accès basés sur les rôles (RBAC) et d'accès juste-à-temps (JIT), de sécurisation des connexions et de traçabilité complète des actions. Toutefois, ce travail présente certaines limites, liées notamment à l'environnement de déploiement local, à l'utilisation de certificats auto-signés, au nombre restreint d'utilisateurs et de ressources testés, ainsi qu'aux limites fonctionnelles de la solution open-source Teleport.

En termes de perspectives, ce travail s'ouvre sur plusieurs pistes d'évolution, notamment l'extension de l'architecture à d'autres types de ressources, telles que les clusters Kubernetes et les serveurs Windows, l'export des journaux vers un SIEM pour la corrélation des événements et la génération d'alertes, l'automatisation du workflow JIT, l'intégration d'un fournisseur d'identité ainsi que le déploiement en environnement de production afin d'analyser le comportement de l'architecture dans des conditions réelles d'exploitation.

Bibliographie

- [5] S. ROSE, O. BORCHERT, S. MITCHELL et S. CONNELLY, “Zero Trust Architecture”, en, National Institute of Standards et Technology, rapp. tech., août 2020. DOI : [10.6028/NIST.SP.800-207](https://doi.org/10.6028/NIST.SP.800-207). adresse : <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf> (visité le 02/07/2025).
- [7] R. SANDHU, E. J. COYNE, H. L. FEINSTEIN et C. E. YOUMAN, “Role-based access control models”, *IEEE Computer*, t. 29, n° 2, p. 38–47, 1996.
- [8] M. K. CARTER, “Techniques to approach least privilege”, *IDPro Body of Knowledge*, t. 1, n° 9, 2022. DOI : [10.55621/idpro.88](https://doi.org/10.55621/idpro.88). adresse : <https://bok.idpro.org/article/id/88/>.
- [10] R. ROSS, V. PILLITTERI et J. T. FORCE, “Security and privacy controls for information systems and organizations”, National Institute of Standards et Technology, rapp. tech. NIST SP 800-53 Rev. 5.1, 2024. DOI : [10.6028/NIST.SP.800-53r5.1](https://doi.org/10.6028/NIST.SP.800-53r5.1). adresse : <https://doi.org/10.6028/NIST.SP.800-53r5.1>.

Webographie

- [1] *Identity and access management*, fr, Page Version ID : 1294614911, juin 2025. adresse : https://en.wikipedia.org/w/index.php?title=Identity_and_access_management&oldid=1294614911 (visité le 01/07/2025).
- [2] L. SHARMA, *Les meilleures solutions de gestion des accès privilégiés (PAM) en 2025*, fr, juil. 2022. adresse : <https://geekflare.com/fr/best-privileged-access-management-solutions/> (visité le 29/07/2025).
- [3] *What is Identity and Access Management (IAM) ?*, en. adresse : <https://delinea.com/what-is/identity-and-access-management-iam> (visité le 14/08/2025).
- [4] C. CUNNINGHAM, *A Look Back At Zero Trust : Never Trust, Always Verify*, fr, août 2020. adresse : <https://www.forrester.com/blogs/a-look-back-at-zero-trust-never-trust-always-verify/> (visité le 21/08/2025).
- [6] *Qu'est-ce qu'une Public Key Infrastructure (PKI) ? Signification de PKI | Entrust*, fr. adresse : <https://www.entrust.com/fr/resources/learn/what-is-pki> (visité le 02/07/2025).
- [9] *Just-In-Time (JIT) Access Management : The Essential Guide*, fr, Section : Articles, mar. 2025. adresse : <https://www.apono.io/blog/just-in-time-jit-access-management-the-essential-guide/> (visité le 14/08/2025).

Annexe

Fichier de configuration teleport.yaml du cluster

La figure A.1 présente le fichier de configuration du cluster Teleport.

```
version: v3
teleport:
  nodename: teleport
  data_dir: /var/lib/teleport
  join_params:
    token_name: ""
    method: token
  log:
    output: stderr
    severity: INFO
    format:
      output: text
  ca_pin: "sha256:531de4155edb9067dab7fcf326b63a5c923473f2d6d46d305cb8fa962c24ea9f"
  diag_addr: ""
  auth_service:
    enabled: "yes"
    listen_addr: 0.0.0.0:3025
    cluster_name: teleport.local
    proxy_listener_mode: multiplex
  ssh_service:
    enabled: "no"
  proxy_service:
    enabled: "yes"
    listen_addr: 0.0.0.0:3023
    web_listen_addr: 0.0.0.0:3080
    public_addr: teleport:3080
```

Figure A.1 – Fichier de configuration teleport.yaml

Fichiers de configuration des serveurs SSH et de l'application web

Les figures A.2, A.3 et A.4 présentent les fichiers de configuration de chaque ressource.

```

version: v3
teleport:
  nodename: SSH-Sandbox
  data_dir: /var/lib/teleport-node1
  log:
    output: stderr
    severity: INFO
    format:
      output: text
  ca_pin: "sha256:531de4155edb9067dab7fcf326b63a5c923473f2d6d46d305cb8fa962c24ea9f"
  diag_addr: ""
auth_service:
  enabled: "no"
ssh_service:
  enabled: "yes"
  listen_addr: 0.0.0.0:3022
  labels:
    env: dev
  commands:
    - name: os_user
      command: ["/usr/bin/whoami"]
      period: 1s
proxy_service:
  enabled: "no"

```

Figure A.2 – Fichier de configuration teleport-node1.yaml

```

version: v3
teleport:
  nodename: File-server
  data_dir: /var/lib/teleport-node2
  log:
    output: stderr
    severity: INFO
    format:
      output: text
  ca_pin: "sha256:531de4155edb9067dab7fcf326b63a5c923473f2d6d46d305cb8fa962c24ea9f"
  diag_addr: ""
auth_service:
  enabled: "no"
ssh_service:
  enabled: "yes"
  listen_addr: 0.0.0.0:4022
  labels:
    env: prod
    role: file_server
  commands:
    - name: os_user
      command: ["/usr/bin/whoami"]
      period: 1s
proxy_service:
  enabled: "no"

```

Figure A.3 – Fichier de configuration teleport-node2.yaml

```

version: v3
teleport:
  nodename: portail-marketing
  data_dir: /var/lib/teleport-app
  join_params:
    token_name: ""
    method: token
  proxy_server: "teleport:3080"
  log:
    output: stderr
    severity: INFO
    format:
      output: text
  ca_pin: "sha256:531de4155edb9067dab7fcf326b63a5c923473f2d6d46d305cb8fa962c24ea9f"
  diag_addr: ""
app_service:
  enabled: "yes"
  apps:
    - name: "portail-marketing"
      uri: "http://marketing:8080"
      labels:
        env: "prod"
        team: "marketing"

```

Figure A.4 – Fichier de configuration de l'application web

Script d'initialisation de la base de données MySQL

Le script SQL suivant regroupe l'ensemble des commandes exécutées pour l'initialisation de la base de données MySQL avant son intégration.

Script d'initialisation de la base de données

```

CREATE DATABASE `DB-Clients`;
USE DB-Clients;
CREATE TABLE accounts (
  username VARCHAR(50)
);
CREATE USER 'teleport_reader'@'%' IDENTIFIED BY '';
CREATE USER 'teleport_writer'@'%' IDENTIFIED BY '';

# droit de lecture uniquement
GRANT SELECT ON accounts TO 'teleport_reader'@'%';

# droit de lecture, d'insertion, de modification et de suppression.
GRANT SELECT, INSERT, UPDATE, DELETE ON accounts TO 'teleport_writer'
@'%';

```

Figure A.5 – Script d'initialisation de la base DB-Clients

Table des matières

Dédicace	ii
Remerciements	iii
Résumé	iv
Abstract	v
Liste des figures	vi
Liste des tableaux	viii
Liste des sigles et acronymes	ix
Introduction	1
1 Revue de littérature	3
Introduction	3
1.1 Clarifications conceptuelles	3
1.1.1 IAM (Identity and Access Management)	3
1.1.2 Le Modèle Zero Trust	4
1.1.3 Authentification et Gestion des Identités	5
1.1.3.1 Authentification Multi-Facteurs (MFA)	5
1.1.3.2 La PKI (Public Key Infrastructure) et les Certificats Éphémères	5
1.1.4 Contrôle d'Accès et Gestion des Privilèges	5
1.1.4.1 RBAC (Role-Based Access Control)	5
1.1.4.2 Just-In-Time (JIT) Access	6
1.2 Audit de sécurité et traçabilité des actions	7
1.3 Outils existants de gestion des accès	7
1.3.1 Présentation des solutions traditionnelles de gestion des accès	8
1.3.2 Présentation des solutions modernes de gestion des accès	8
1.3.3 Tableau récapitulatif des outils présentés	9
1.3.4 Justification du choix de Teleport	9
Conclusion	10
2 Mise en œuvre	11
Introduction	11
2.1 Présentation de l'architecture conçue	11
2.2 Description technique de l'architecture	12

2.3	Mise en œuvre	14
2.3.1	Déploiement du plan de contrôle	14
2.3.2	Intégration du plan de ressources	15
2.3.2.1	Intégration des serveurs SSH	15
2.3.2.2	Intégration de la base de données MySQL	16
2.3.2.3	Intégration de l'application web	17
2.3.3	Gouvernance des privilèges	18
2.3.3.1	Environnement de développement (env : dev)	18
2.3.3.2	Environnement de production (env : prod)	19
2.4	Tests de validation	21
2.4.1	Centralisation de l'accès aux ressources	21
2.4.2	Segmentation des ressources	22
2.4.3	Gouvernance des privilèges (RBAC et JIT)	22
2.4.3.1	Validation des politiques d'accès (env : dev)	22
2.4.3.2	Validation des politiques d'accès (env : prod)	22
2.4.4	Sécurité des communications et de l'authentification	23
2.4.5	Audit et traçabilité	24
	Conclusion	25
3	Résultats	26
	Introduction	26
3.1	Résultat de la centralisation de l'accès aux ressources	26
3.2	Résultat de la segmentation des ressources	28
3.3	Résultat de la Gouvernance des privilèges (RBAC et JIT)	29
3.3.1	Environnement de développement	29
3.3.2	Environnement de production	30
3.4	Résultat de la sécurité des communications et de l'authentification	31
3.5	Résultat de l'audit et de la traçabilité	33
3.6	Analyse des résultats obtenus	34
3.7	Discussion	35
	Conclusion	37
	Conclusion	38
	Bibliographie	39
	Webographie	40
	Annexe	41
	Table des matières	44
